

Chapter 8: Operational Security

Isolation, Attribution, and Metadata Protection for Investigators

Companion Workbook to the Instructional Video

How to Use This Workbook

This is the written companion to the instructional video on operational security. It works as a follow-along guide, a standalone textbook chapter, and a practice manual.

Where this chapter sits in the series. Chapters 1 through 3 covered intelligence, OSINT, and sources. Chapter 4 covered the collection process, Chapter 5 the reasoning, Chapter 6 the planning and evidence discipline, and Chapter 7 the ethical and legal constraints. **This chapter covers protecting the investigation and the investigator.**

Everything so far has been about what you do to the outside world. This chapter is about what the outside world can see of you: your identity, your organization, your interest, your methods, and the people you are working with. It is defensive throughout.

Time estimate:

Component	Estimated time
Video	60 to 75 minutes
Reading material	5 to 6 hours
Knowledge assessment	1 hour
Critical thinking exercises	2 hours
Labs 1 through 5	11 to 16 hours
Capstone assignment	6 to 9 hours
Total	26 to 35 hours

Materials: a computer on which you are permitted to create browser profiles, a word processor, and the Lab 3 sample file set provided alongside this workbook. Labs 1 and 2 include no-network fallback paths, because many students will be working on institutional or employer machines where installing software or changing network configuration is not permitted. **Do not install anything, change any network setting, or run any tool on a machine you do not control or are not authorized to modify.** Section 8.1.2 covers this before the first lab.

The Rules Still Apply

Rule 1: No private individuals. Rule 2: Publicly available means genuinely public. Rule 3: Document as you go. Rule 4: No dark web access. Rule 5: Automation is constrained. Rule 6: A relationship is a claim, and every claim needs a basis. Rule 7: If it is not written down, it did not happen. Rule 8: Lawful is the floor, not the ceiling.

This chapter adds the rule that keeps operational security from becoming something else:

Rule 9: OPSEC never buys access. If the purpose of a measure is to obtain something you could not obtain openly, it is not OPSEC.

Operational security protects the integrity of a lawful inquiry: it stops a subject from learning that they are being examined before that is appropriate, it prevents your organization's interest from becoming public, it protects sources and colleagues, and it keeps your personal life separate from your professional work. Those are defensive purposes.

The moment a measure's purpose becomes reaching material you could not reach as yourself, it has stopped being OPSEC and become circumvention, which Rule 2 prohibits and which Chapter 7 explains is frequently unlawful. **A research browser profile that does not misrepresent who you are is OPSEC. A fabricated persona created to get past a restriction is not, and no amount of technical sophistication changes that.**

This distinction runs through the whole chapter, and Section 1.7 addresses it directly, because "disposable identities" is the topic where students most often lose it.

Learning Objectives

Knowledge objectives (you can explain it):

1. Define operational security and explain the OPSEC process as a repeatable cycle.
2. Distinguish privacy, anonymity, and confidentiality, and explain why they require different measures.
3. Explain what an ordinary website can observe about a visitor, and what it cannot.
4. Explain browser fingerprinting and why it defeats several intuitive privacy measures.
5. Distinguish private browsing mode, browser profiles, and true browser isolation.
6. Explain what virtual machines and containers provide, and their limits.
7. Explain what a VPN does and does not do, and what changes when you use one.
8. Explain how Tor works at a conceptual level, what it protects, and what it does not.
9. Distinguish a compartmentalized investigative identity from a false persona, and state where the line is.

10. Explain the elements of secure communication: encryption in transit and at rest, end-to-end encryption, authentication, and verification.
11. Explain attribution: the signals that connect activity to a person or organization, and how they combine.
12. Explain what metadata is, where it hides, and how it is removed before publication.

Application objectives (you can do it):

1. Build a threat model for an investigation, identifying adversaries, capabilities, and consequences.
2. Configure a dedicated investigation workspace using browser profiles, and document the isolation it provides and does not provide.
3. Compare browsing configurations and document their strengths, limits, and appropriate uses.
4. Identify metadata in documents, images, and PDFs, and produce a pre-publication protection checklist.
5. Design a secure communications plan covering authentication, encryption, account management, and file sharing.
6. Conduct an OPSEC assessment of an investigation and produce prioritized recommendations.

Analysis objectives (you can judge it):

1. Select proportionate measures for a stated threat model, and recognize both over-engineering and under-protection.
 2. Evaluate an OPSEC posture and identify the weakest link.
 3. Judge whether a proposed measure is defensive or is circumventing a restriction.
 4. Assess the trade-offs a measure imposes on evidence quality, usability, and legality.
-

Part 1: Reading Material

1.1 Introduction to Operational Security

1.1.1 What OPSEC Is

Operational security (OPSEC) is the practice of identifying information about your own activity that an adversary could use, assessing the risk, and applying proportionate measures to reduce it.

It originated in military planning and generalizes cleanly: the observable traces of what you are doing can tell an observer what you are doing, even when the substance is protected. An organization that keeps its plans secret and simultaneously books forty hotel rooms in one town has not kept its plans secret.

For an investigator, the observable traces include visits to a subject's website, records requests, professional profile views, questions asked, purchases made, accounts created, and the metadata in the documents you send.

1.1.2 The Boundaries of This Chapter

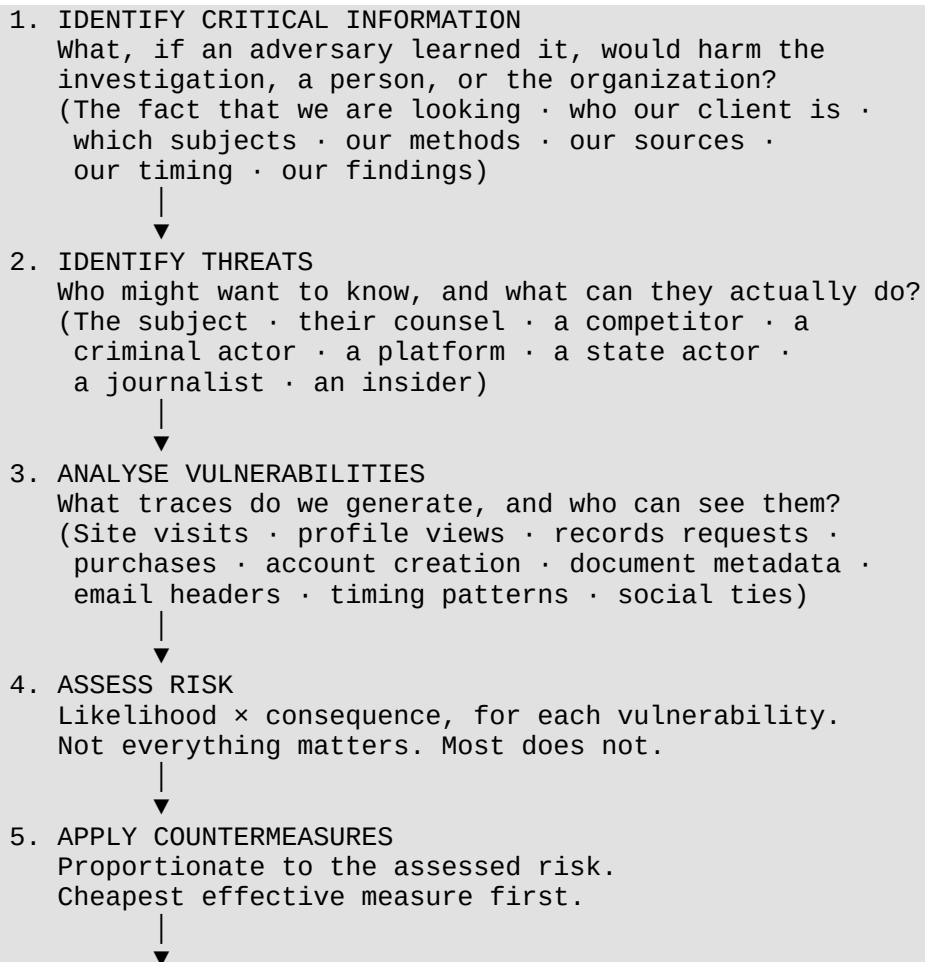
Three limits, stated before anything else.

This chapter is defensive. Every technique here exists to protect a lawful investigation, its participants, and the investigator's own privacy. Rule 9 governs.

Do not modify machines you do not control. Many readers will be on employer or institutional equipment. Installing software, changing network configuration, or running unfamiliar tools on such a machine can breach policy, break monitoring your organization relies on, and in some contexts constitute unauthorized modification. Every lab in this chapter has a path that requires no installation and no configuration changes.

Corporate and institutional policy governs. If your organization requires that traffic pass through its monitoring, using a personal VPN to avoid that is a policy violation and possibly worse. OPSEC measures are chosen with your organization, not around it.

1.1.3 The OPSEC Cycle



6. REVIEW

Did the measures hold? Has the threat changed?
Has the investigation's phase changed?

→ back to 1

Step 4 is the one students skip, and skipping it produces both failure modes at once: elaborate protection against threats that do not exist, and no protection against the one that does.

1.1.4 Threat Modelling

A **threat model** is a written statement of who you are protecting against, what they can do, and what it would cost you if they succeeded. Without one, every OPSEC decision is a guess.

Four questions:

Question	Purpose
What am I protecting?	The critical information from step 1
Who am I protecting it from?	Specific adversaries, not "hackers"
What can they actually do?	Capability, not imagination
What happens if they succeed?	Consequence, which sets the proportionate spend

A worked example. An investigator researching a mid-sized regional contractor for a client:

Element	Assessment
Protecting	The fact of the investigation, the client's identity, the timing before a board decision
From	The subject company, primarily its marketing and IT staff who watch site analytics; secondarily its counsel
Capability	Can see repeat visits to their own website, can see professional profile views if the platform notifies, can receive notice of a public records request in some jurisdictions, can search their own name and find your firm's activity if it is visible
Consequence if they succeed	The subject prepares, alters public materials, or contacts the client; the client's negotiating position weakens; no physical risk to anyone
Proportionate posture	Moderate. Separate browser profile, archives instead of repeated live visits, no logged-in platform browsing, no purchases, awareness that records requests may be disclosable

A different worked example. A journalist working with a source inside an organization in a country

with an aggressive security service:

Element	Assessment
Protecting	The source's identity, above everything else
From	A state actor with legal compulsion powers, network visibility, and the ability to obtain records from providers
Capability	Very high
Consequence if they succeed	Imprisonment or worse, for the source
Proportionate posture	Very high, and beyond what an individual should design alone. Specialist support, organizational infrastructure, and legal advice are all required

The lesson from the pair: these two investigations need completely different postures, and applying either one's measures to the other is a mistake. The first is over-protected by the second's measures and paralysed by them; the second is catastrophically under-protected by the first's.

1.1.5 The Two Failure Modes

Failure	What it looks like	Cost
Under-protection	No separation between personal and investigative activity; logged-in browsing; repeated live visits to a subject's site; metadata left in delivered documents	The subject learns of the investigation; sources exposed; the investigator's personal life connected to their work
Over-engineering	Elaborate tooling for a low-threat investigation; measures nobody can sustain; configurations that break evidence capture	The measures are abandoned under deadline pressure, usually silently, leaving no protection at all; evidence quality degrades; time is spent on the wrong thing

Over-engineering is more common among students and it is dangerous precisely because it feels responsible. The correct posture is the cheapest set of measures that addresses the assessed threats, chosen so that they can be sustained on the worst day of the investigation.

1.1.6 The Weakest Link

OPSEC fails at its weakest point, and the weakest point is rarely technical.

Layer	Typical weakest link
Technical	The one machine that was not configured; the personal phone used "just once"

Layer	Typical weakest link
Behavioural	Logging into a personal account in the investigation profile; searching the subject from a personal device out of curiosity
Procedural	The measure that was designed and never written down, so it was not followed
Social	Mentioning the case at a conference; a colleague's out-of-office reply naming the client
Documentary	Metadata in a delivered report naming the author, the organization, and the template
Temporal	A pattern of activity that reveals a working schedule and therefore a location or an organization

The consistent finding across the case studies in Part 3: the failure was almost never a defeated technical control. It was a person doing an ordinary thing in the wrong context.

1.1.7 OPSEC and Evidence Quality Can Conflict

A tension this chapter takes seriously and most treatments ignore.

Chapter 6 requires you to capture evidence with URLs, timestamps, and reproducible conditions. Some OPSEC measures degrade exactly that: content differs by geography, so a VPN exit in another country may show you a different page from the one a court cares about; a hardened browser configuration may break page rendering and produce incomplete captures; an isolated environment may complicate hashing and transfer workflows.

Measure	Evidence impact	Mitigation
VPN exit in another jurisdiction	Geographic content variation; capture may not reflect what a local user sees	Record the exit location in the capture record; capture from the relevant geography where the geography matters
Aggressive script and content blocking	Incomplete page rendering	Capture with a documented standard configuration; note blocking in the capture record
Isolated VM	Transfer friction for evidence out of the environment	Define the transfer and hashing workflow in the plan (Chapter 6)
Tor exit	Frequent geographic and access variation; some sites block it	Do not use for evidentiary capture unless the plan justifies it and records it
Disposable profile with no history	Some sites behave differently for new sessions	Note the session state in the capture record

The rule: whatever configuration you use, record it in the capture record, and prefer the configuration that produces the most representative capture unless the threat model requires otherwise.

1.2 Anonymous Browsing

1.2.1 What a Website Can See

Before discussing protection, be precise about the exposure. An ordinary website you visit, with no special effort on its part, typically observes:

Observable	What it reveals
IP address	Approximate location, and the network operator: a residential provider, a mobile carrier, a hosting provider, or an identifiable organization
Reverse DNS on that address	For organizational networks, frequently the organization's name
User agent string	Browser, version, and operating system
Language and locale settings	Country and language preferences
Time zone	Approximate location, independently of the IP
Screen resolution and window size	A fingerprinting component
Installed fonts, rendering behaviour, hardware characteristics	Strong fingerprinting components
Referring page	Where you came from, including a search query in some configurations
Cookies and stored identifiers	Prior visits, and links to activity on other sites
Logged-in session	Your identity, directly
Timing and pattern of visits	A working schedule, therefore a time zone and often an organization

The single most consequential line is the logged-in session. Every technical measure in this chapter is defeated instantly by visiting a subject's site in a browser where you are signed in to a personal account that the site can associate with you, or that shares a session with a platform that does.

1.2.2 Browser Fingerprinting

Fingerprinting is identifying a browser by the combination of its observable characteristics rather than by a stored identifier. Individually, the characteristics are unremarkable; combined, they are frequently unique or nearly so.

Why it matters practically:

- Clearing cookies does not change your fingerprint.

- Private browsing mode does not change your fingerprint.
- Changing your IP address does not change your fingerprint.
- Adding unusual privacy extensions can make your fingerprint **more** distinctive, not less.

The counterintuitive consequence: a heavily customized "privacy" browser can be more identifiable than a default one, because it is rarer. The measures that genuinely reduce fingerprinting work by making a browser look like many other browsers, which means accepting a standard configuration rather than a personalized one.

The practical position for most investigators: fingerprinting is a real exposure and it is rarely the binding constraint. Session separation, IP awareness, and behavioural discipline matter more for ordinary investigative threat models. Do not spend your effort here unless your threat model justifies it.

1.2.3 What "Private Browsing" Actually Does

Private or incognito mode is widely misunderstood, and the misunderstanding causes real exposure.

It does	It does not
Prevent history from being saved locally	Hide your IP address
Isolate cookies from the normal session for the duration of the window	Prevent fingerprinting
Discard cookies when the window closes	Hide activity from your network operator or employer
Prevent local autofill and cached credential use	Hide activity from the sites you visit
Give you a clean session for a specific task	Make you anonymous in any meaningful sense

Private browsing is a local privacy feature. It protects you from other people using your computer. It provides almost nothing against the site you are visiting, which is the direction investigators care about.

1.2.4 The Measures That Actually Help

In rough order of value per unit of effort, for ordinary investigative threat models:

Measure	What it addresses	Effort
Never browse investigation targets while signed in to personal accounts	The direct identity leak	None; a discipline
A separate browser profile for investigative work	Session, cookie, history, and autofill separation	Minutes; no installation
Use archives instead of repeated live visits	Repeat-visit patterns in the subject's analytics	Low; and it improves evidence (Chapter 3)
Awareness of the network you are on	Organizational attribution through the IP and reverse DNS	None; a decision

Measure	What it addresses	Effort
Disable or scope link previews and automatic loading in tools that fetch on your behalf	Unintended fetches from your address	Low
A separate device or VM for higher-risk work	Cross-contamination of all kinds	Moderate
VPN, where the threat model justifies it	IP-based location and organizational attribution	Low to moderate, with trade-offs
Fingerprint-resistant configurations	Fingerprinting	High effort, high usability cost

The top three items are free and they address the exposures that actually occur in ordinary investigations. Students consistently want to start at the bottom of this table.

1.2.5 The Fetching Problem

A frequently missed exposure: tools that fetch content on your behalf can reveal your interest even when you never visit a site.

Tool	The exposure
A messaging app that generates a link preview	The app's server, or in some configurations your device, fetches the URL when you paste it
A document editor that resolves an embedded image	Fetches from your address when the document is opened
An email client that loads remote images	Signals that the message was opened, and from where
A browser that prefetches links on a page	Fetches pages you never clicked
A monitoring or archiving service	Fetches on a schedule, from its own addresses, which may be identifiable
A URL shortener or scanner	Records the URL and may make it discoverable

Two practical consequences. Pasting a subject's URL into a chat with a colleague may notify the subject's server that someone looked. And submitting a URL to a public scanning or archiving service may make your interest visible to anyone who queries that service later, which is a well-known pattern.

1.3 Browser Isolation

1.3.1 Three Levels of Separation

"Browser isolation" is used loosely. Distinguish three things:

Level	What it is	What it separates	What it does not
Private browsing mode	A temporary session in the same browser	History and cookies from the normal session, temporarily	Nothing from the site; nothing from the network
Separate browser profile	A distinct profile with its own cookies, storage, history, extensions, and signed-in state	All browser state between contexts, persistently	The IP address; the fingerprint; the machine
True isolation	Browsing executed in a separate environment: a VM, a container, or a remote browser service that streams only pixels	The execution environment, so that content never runs on your machine	The IP address, unless combined with a network measure

1.3.2 Browser Profiles: The Highest-Value Measure

A separate browser profile is the single best return on effort in this chapter for most investigators. It requires no installation, no administrative rights, and about five minutes.

What it provides:

- A clean, separate cookie and storage jar, so a subject's site cannot see your other sessions and your personal sessions cannot leak into investigative browsing.
- Separate signed-in state, which prevents the catastrophic case in Section 1.2.1.
- Separate history and autofill, so a screen shared in a meeting does not reveal your investigation, and an autofill suggestion does not reveal a personal detail.
- Separate extensions, so a personal extension that syncs or reports activity is not present in investigative browsing.
- A deliberate context switch, which is a behavioural benefit as much as a technical one.

What it does not provide: any change to your IP address, any change to your fingerprint, or any protection if the machine itself is compromised.

The discipline that makes it work:

Rule	Reason
Never sign in to a personal account in the investigation profile	Defeats the entire purpose in one action
Never use the investigation profile for personal browsing	Contaminates the profile with personal signals
Disable synchronization in the investigation profile	Sync ties the profile to an account and to your other devices

Rule	Reason
Keep extensions to the minimum needed	Every extension is a potential channel and a fingerprint component
Name the profile so the context is visible	Prevents the wrong-window error
One profile per case where cases must not be linked	Cross-case contamination is a real exposure

1.3.3 Remote and Streamed Browsing

Some organizations provide **remote browser isolation**: the browser runs on a server elsewhere and streams the rendered result to you. The content never executes on your machine.

Strength	Limitation
Malicious content cannot reach your machine	The service operator can see everything you do
The visited site sees the service's address, not yours	The service's addresses may be identifiable as such, and some sites block them
Centrally managed and consistent	Capture and download workflows are frequently awkward, which matters for evidence
Sessions can be genuinely disposable	Cost, and dependence on an external provider

Where it fits: it is genuinely valuable for the malware-adjacent side of investigative work and for organizations that need central control. It is not primarily an anonymity measure.

1.3.4 Choosing a Level

```

Does the work involve content that might be hostile
(malware distribution, attacker infrastructure)?
  | yes → TRUE ISOLATION (VM, container, or
  |       remote browser). Non-negotiable.
  | no
  ▼ no
Must my personal and investigative browsing be
kept separate?
  | yes → SEPARATE PROFILE, minimum. This is
  |       nearly always the answer.
  | no
  ▼ no
Am I doing a single, low-sensitivity lookup where
local history is the only concern?
  | yes → Private browsing is adequate.
  | no
  ▼ no
Reconsider: if the answer to the second question is
genuinely no, check the threat model again.

```

1.4 Virtual Machines

1.4.1 What a Virtual Machine Provides

A **virtual machine (VM)** is a complete simulated computer running as software on a host machine, with its own operating system, storage, and network identity.

For investigative work it provides four things:

Property	Value
Separation	A distinct operating system environment, so software, credentials, and traces do not mix with the host
Disposability	The machine can be deleted and rebuilt, discarding everything it accumulated
Snapshots	A saved known-good state that can be restored in seconds, which is what makes disposability practical
Containment	Hostile content that executes inside the VM has to escape the VM before reaching the host, which is a meaningful barrier

1.4.2 VMs, Containers, and Physical Machines

Dimension	Physical machine	Virtual machine	Container
What it is	Dedicated hardware	A simulated computer with its own OS	An isolated process environment sharing the host kernel
Isolation strength	Strongest	Strong	Moderate; shares the kernel with the host
Resource cost	Highest	Moderate	Low
Startup time	Minutes	Tens of seconds	Seconds
Snapshot and rollback	Impractical	Native and fast	By rebuilding from an image
Disposability	Poor	Excellent	Excellent
Runs a full desktop	Yes	Yes	Usually not; designed for services
Suitable for browsing investigations	Yes	Yes, and the usual answer	Rarely; not the intended use
Suitable for hostile content	Yes, if air-gapped and rebuilt	Yes, with care	No
Network identity	The host network	Configurable: shared	Usually the host's

Dimension	Physical machine	Virtual machine	Container
		with the host or separate	
Common misconception	That a separate machine hides your network	That a VM changes your IP address	That containers isolate as strongly as VMs

Two misconceptions to correct explicitly. A VM does not change your IP address; by default its traffic leaves through the same network connection as the host, and the sites you visit see the same address. And containers share the host kernel, which makes them excellent for reproducibility and unsuitable as a security boundary against hostile content.

1.4.3 A Practical Investigation VM

For an ordinary investigative threat model, a workable configuration:

Element	Choice	Reason
Guest operating system	A mainstream desktop OS, kept updated	Blending in matters more than exotic choices
Snapshot	Taken immediately after configuration, before any use	The clean state to return to
Rollback policy	After any case, or after any encounter with hostile content	Disposability is only real if you use it
Accounts	No personal accounts, ever	The same discipline as browser profiles
Shared folders with the host	Disabled by default; enabled only for a defined evidence transfer step	Shared folders are the usual path for contamination in both directions
Clipboard sharing	Disabled	A common accidental leak channel
Network mode	Understood and recorded; default is shared with the host	So you know what the visited site sees
Time zone and locale	Consider matching the host, or a documented deliberate choice	An unusual mismatch is itself a signal
Evidence handling	Defined transfer and hashing workflow (Chapter 6)	Isolation must not degrade the evidence record

The most common practical failure with VMs is that they are configured once, never snapshotted, gradually accumulate personal use, and become a second unmanaged machine. The snapshot and rollback discipline is what distinguishes a VM from a slow laptop.

1.4.4 Limits

- A VM does not change your network identity.

- A VM does not protect against a compromised host.
 - VM escape is possible, and rare; treat a VM as a strong barrier rather than an absolute one.
 - A VM used for a genuinely high-risk task should be rebuilt afterward rather than reused.
 - Running a VM may itself be visible to your organization's management tooling, and on managed devices may not be permitted at all.
-

1.5 VPNs

1.5.1 What a VPN Actually Does

A **virtual private network (VPN)** creates an encrypted tunnel from your device to a server operated by the VPN provider. Your traffic emerges from that server and reaches its destination with the server's address rather than yours.

What changes:

Before	After
Sites see your real IP address	Sites see the VPN server's address
Your network operator sees which sites you connect to	Your network operator sees that you connect to a VPN, and the volume and timing
Your traffic is visible to intermediate networks to the extent it is unencrypted	Traffic between you and the VPN server is encrypted

What does not change:

Unchanged
Your browser fingerprint
Your cookies and logged-in sessions
Anything you type, submit, or log in to
The content you request, as seen by the destination site
Your behaviour, timing, and patterns

1.5.2 The Trust Shift

The most important idea in this section. **A VPN does not remove the party who can see your activity. It changes who that party is.**

Without a VPN, your network operator sees your destinations. With a VPN, the VPN provider sees them. Whether that is an improvement depends entirely on which party you are trying to protect against and how much you trust the provider.

Question about a provider	Why it matters
What does it log, and for how long?	Logging policies vary and are frequently unverifiable from outside
Where is it established, and under whose legal compulsion?	Jurisdiction determines who can compel disclosure
Who owns it?	Provider ownership is often opaque and has changed hands quietly
Has it been independently audited?	An audit is evidence; marketing is not
Does it leak DNS or IP under failure?	A tunnel that fails open exposes exactly what it was protecting
Are its addresses widely known as VPN addresses?	Many sites treat them differently or block them

A free VPN warrants particular caution, because running the infrastructure costs money, and where the service is free the revenue is coming from somewhere.

1.5.3 When a VPN Helps and When It Does Not

Situation	Does a VPN help?
Preventing a subject's website from seeing your organization's address	Yes, this is the core use
Working on untrusted public networks	Yes, though widespread encryption has reduced this benefit
Preventing your employer from seeing your work traffic	Usually a policy violation; do not
Making you anonymous	No
Preventing fingerprinting	No
Preventing a site from identifying you when signed in	No, not at all
Hiding your activity from the VPN provider	No, by definition
Accessing something you are not permitted to access	No, and Rule 9 applies
Producing evidence that reflects what a local user would see	It can actively harm this, depending on exit location

1.5.4 Practical Considerations

- **Record the exit location** in every capture record, because content varies by geography.
- **Understand the failure mode:** does the connection block traffic if the tunnel drops, or does it

fail open?

- **Check for DNS leakage**, which is the most common way a VPN silently fails to protect what the user assumed.
- **Expect friction**: many sites present additional verification, restrict functionality, or block known VPN addresses entirely, which can degrade capture quality.
- **Do not use a VPN to circumvent your own organization's controls.**
- **Choose the exit location deliberately.** An exit in an unexpected country is itself a signal, and it changes the content you receive.

1.6 Tor

1.6.1 What Tor Is

Tor is a network that routes traffic through multiple volunteer-operated relays, encrypting it in layers so that no single relay knows both the origin and the destination.

At a conceptual level:

```
YOU → ENTRY RELAY → MIDDLE RELAY → EXIT RELAY → SITE
```

```
Entry relay:  knows your address, not your destination
```

```
Middle relay: knows neither endpoint
```

```
Exit relay:   knows the destination, not your address
```

```
Each hop peels one layer of encryption. No single relay  
sees both ends of the circuit.
```

That separation is the design property, and it is what distinguishes Tor from a VPN, where a single party sees both ends.

1.6.2 What Tor Protects and What It Does Not

Protects	Does not protect
Your address from the destination site	Anything you log in to or submit
Your destinations from your local network operator	Your behaviour and writing style
Against any single relay operator learning both ends	Against traffic correlation by an adversary observing both ends of the network
The location of certain services from their visitors	Against malware executing on your machine
	Against you deanonymizing yourself through content

The most common deanonymization is self-inflicted. Signing in to an account, submitting an

identifying detail, or writing in a recognizable way defeats the network entirely, and no amount of routing helps.

1.6.3 Limits That Matter for Investigators

Limit	Consequence
Slow, by design	Poor experience for volume work
Many sites block known exit addresses	Frequent inability to reach the material you need
Exit locations vary unpredictably	Geographic content variation; poor for evidentiary capture
Exit relays can observe unencrypted traffic	Anything not encrypted end to end is visible at the exit
Using Tor is itself observable to your local network	In some contexts, that observation is the exposure
Institutional policy frequently prohibits it	Check before, not after

1.6.4 Tor in This Course

Rule 4 remains in force: no dark web access. Chapter 3 explained the reasoning at length, and none of it changes here.

Tor as a network and the sites reachable only through it are different things. Understanding Tor is part of understanding the internet's architecture, and it has legitimate uses: circumventing censorship, protecting sources, and reaching services that publish through it for good reasons.

For this course: you will learn what Tor is, what it protects, and where it fits. You will not use it to reach onion services, and the labs do not require you to install or run it. If your institution or employer prohibits it, that prohibition governs.

1.6.5 Choosing Between Direct, VPN, and Tor

If your concern is	Use
Nothing in particular; ordinary public records research	A direct connection, with a separate browser profile
A subject seeing your organization's address in their analytics	A VPN, with the exit recorded
Producing evidence that reflects a specific geography	A direct connection from that geography, or a documented VPN exit there
A hostile local network	A VPN, or better, do not work from that network
Protecting a source in a high-risk environment	Specialist support and organizational infrastructure, not a personal choice
Reaching material you are not permitted to reach	Nothing. Rule 9

1.7 Disposable and Compartmentalized Identities

1.7.1 *The Distinction That Governs This Section*

This is the topic where students most often go wrong, so the line is drawn first.

Compartmentalized investigative identity	False persona
A separate work account, email address, and profile used for investigative work	A fabricated identity presenting as someone who does not exist, or as someone else
Does not claim to be anyone in particular	Claims to be a particular kind of person, or a specific person
Purpose: keep personal life separate from professional work	Purpose: obtain access or information that would not be given to you
Used to hold a subscription, receive records, or browse without personal signals	Used to join a group, befriend a subject, or pass a verification
Consistent with Rule 2 and Rule 9	Prohibited by Rule 2, and frequently unlawful
Example: a work email address, <code>research@[firm]</code> , used for records requests and subscriptions	Example: a profile of a fictitious person, used to send a connection request to a subject

The test: if the identity's purpose is to prevent your personal life from being attached to your professional work, it is compartmentation. If its purpose is to be treated as someone you are not so that access is granted, it is a false persona and it is outside this course.

Nothing in this section teaches persona creation, and requests along those lines are declined for the reasons Chapter 7 sets out.

1.7.2 *Why Compartmentation Matters*

Compartmentation limits the blast radius of any single exposure.

Without compartmentation	With compartmentation
One email address links your investigative subscriptions, your personal shopping, and your family	Separate addresses, separately exposed
A breach of a records service exposes your personal address	A breach exposes a work address that reveals nothing personal
A subject who learns of one activity can find all your others	The subject learns of one context
Cases can be linked to one another through shared	Each case's traces are separate

Without compartmentation	With compartmentation
accounts	
Your working hours reveal your location and organization	Only where the account is shared across contexts

1.7.3 Levels of Compartmentation

Level	Separation	Appropriate when
None	Personal accounts and devices used for everything	Never, for professional investigative work
Personal versus professional	A work identity distinct from personal life	The baseline for all professional work
Per-function	Separate accounts for records subscriptions, platform access, and correspondence	Moderate threat models
Per-case	Separate accounts and profiles per investigation, so cases cannot be linked	Where linking cases would harm a client or a subject
Per-source	Separate channels per sensitive source	Journalism and high-risk work; requires organizational support

Compartmentation has a cost, and the cost is administrative: more accounts, more credentials, more places to make an error, and more chances to use the wrong one. Choose the level your threat model justifies and that you can sustain.

1.7.4 Managing Compartmented Accounts

Practice	Reason
A password manager, with separate vaults per context where the tooling supports it	Reuse across contexts is the classic linking mechanism
Unique, strong credentials per account	Breach of one does not reach the others
Phishing-resistant multi-factor authentication where available	Account takeover is a realistic exposure for investigators
Recovery details that do not link contexts	Recovery email and phone numbers are the most common linking channel and are routinely forgotten
A written account register, held securely	You cannot manage what you cannot enumerate; Chapter 6's documentation discipline applies
Accurate identifying information where the service requires it	Rule 9: compartmentation does not license misrepresentation to a service

Practice	Reason
Defined closure: which accounts are closed at case end	Otherwise accounts accumulate indefinitely, each an exposure

The recovery-detail link is worth emphasizing. Two accounts that appear entirely separate are linked if both list the same recovery phone number, and this is the mechanism by which compartmentation most often silently fails.

1.7.5 Behavioural Compartmentation

Technical separation fails if behaviour crosses contexts.

Leak	Example
Writing style	The same distinctive phrasing in a work post and a personal one
Timing	Both accounts active only during one time zone's working hours
Interests	The same niche subject appearing in both contexts
Errors	The same characteristic typo
Cross-posting	Sharing between contexts, even once
Reuse of images	The same photograph, which is trivially reverse-searchable (Chapter 2)
Device	Both accounts used from one device with a shared fingerprint or shared session state

Behavioural leaks are the hardest to control and the reason that heavy compartmentation is genuinely difficult to sustain. Another argument for choosing the lowest level that meets the threat model.

1.8 Secure Communications

1.8.1 What "Secure" Has to Mean

"Secure communication" is four distinct properties, and a channel can have some without others.

Property	Question	Failure looks like
Confidentiality	Can anyone other than the intended parties read it?	Contents intercepted
Integrity	Can it be altered undetectably in transit?	Modified message accepted as genuine

Property	Question	Failure looks like
Authentication	Am I certain who I am talking to?	Talking to an impostor with perfect encryption
Availability and deniability considerations	Can it be blocked, and what does its existence reveal?	The fact of the communication is itself the exposure

Authentication is the property investigators most often skip. An encrypted channel to the wrong party is worse than an unencrypted one, because it feels safe.

1.8.2 Encryption in Transit, at Rest, and End to End

Type	What it protects	Who can still read it
In transit	Data moving between you and a server	The server operator, at both ends of the hop
At rest	Data stored on a device or server	Anyone with access to the key or to an unlocked device
End to end (E2EE)	Data from sender to recipient, with keys held only by them	Only the endpoints; the service operator cannot read content

The distinction that matters: a service can be "encrypted" in the transit and at-rest senses while the operator can read everything. End to end encryption is the property that removes the operator from the set of readers, and it is the one to ask about specifically.

What E2EE does not protect:

Not protected	Why
Metadata: who, when, how often, how much	Usually visible to the operator regardless
Endpoints	A compromised or unlocked device exposes everything
Backups	An unencrypted backup of an encrypted chat is an unencrypted chat
Recipients' behaviour	They can screenshot, forward, or be compelled
Group membership	Frequently visible to the operator

1.8.3 Metadata in Communications

Chapter 3 established that metadata is data about data. In communications it is frequently more revealing than content.

Metadata	What it reveals
Who communicated with whom	The relationship, which is often the whole finding

Metadata	What it reveals
When and how often	Working patterns, urgency, time zone
Message sizes and timing	Whether a document was sent, and roughly how large
Location, where attached	Where both parties were
Group membership	The set of participants
Email headers	Originating server, relay path, client software, and organizational infrastructure

For an investigator, the practical implication is defensive: the existence and pattern of your communications with a client, a colleague, or a source can be the exposure even when nothing is readable.

1.8.4 Verification

Authentication in practice means verifying that the key you are encrypting to belongs to the person you think.

Method	Strength
Comparing a safety number or fingerprint in person	Strongest
Comparing over a separate, already-trusted channel	Strong
Comparing over the same channel you are verifying	Weak; an impostor controlling the channel controls the comparison
Not verifying at all	The default, and the usual state
Re-verifying after a key change notification	Essential; key change notifications exist precisely for this

Key change notifications are ignored constantly, and they are the one signal that the channel may have changed underneath you.

1.8.5 A Communications Plan

Every investigation should have one. The elements:

Element	Decisions
Parties	Who communicates with whom about this case
Channels	Which channel for which category of content, with a stated reason
Prohibited channels	What must never be used, named specifically

Element	Decisions
Authentication	How each party's identity and keys are verified, and when re-verified
File sharing	How documents move, with encryption, access expiry, and hashing per Chapter 6
Account and device requirements	Multi-factor authentication, device encryption, screen locks, no personal devices where the threat model requires
Naming discipline	Whether the client, subject, and case may be named in messages, and any code designations
Retention	How long messages are kept and how they are removed, aligned to Chapter 7's schedule
Compromise procedure	What happens if a device is lost, an account is taken over, or a message goes to the wrong recipient
Out-of-office and delegation	Automatic replies and delegated access are a frequent leak

The naming discipline row surprises people. An email subject line naming both a client and a subject, sitting in a mailbox that syncs to a phone, is a disclosure risk that no encryption addresses.

1.8.6 File Sharing

Method	Considerations
Email attachment	Simple; metadata-rich; frequently retained indefinitely by both parties and their providers
Encrypted archive by email	Better, if the passphrase travels by a different channel and is strong
Managed file transfer or client portal	Access control, expiry, and an audit trail; usually the right answer for client delivery
Consumer cloud link	Convenient; frequently over-shared, indefinitely available, and outside your control
Physical media	Occasionally appropriate; requires custody discipline (Chapter 6)
Public file-sharing services	Never, for case material

Whatever the method, Chapter 6 applies: hash before sending, hash on receipt, log the transfer, and record the recipient in a production log.

1.9 Preventing Attribution

1.9.1 What Attribution Means Here

Attribution, in the defensive sense, is an observer connecting activity to a person or organization. Preventing unnecessary attribution is the goal; preventing all attribution is neither achievable nor, for most lawful investigations, desirable.

The proportionality point matters. A licensed investigator conducting lawful research has no obligation to be invisible, and elaborate anonymity can look worse than ordinary professional discretion if it ever becomes visible. What you are preventing is *unnecessary* attribution: the subject learning of the inquiry before it is appropriate, your client's identity leaking, or your personal life attaching to your professional work.

1.9.2 The Attribution Signals

Signal	How it attributes
IP address and reverse DNS	Directly names many organizations
Account identity	Logged-in sessions, profile views with notifications, comment history
Device and browser fingerprint	Links sessions to one another
Cookies and stored identifiers	Links visits across time and sites
Timing patterns	Working hours reveal time zone and organizational rhythm
Behavioural patterns	Search phrasing, navigation habits, characteristic errors
Document metadata	Author, organization, template, software (Section 1.10)
Email headers	Originating infrastructure, client software, organizational domains
Payment	Purchases, subscriptions, and records fees, all of which name someone
Records requests	Frequently public or disclosable to the subject
Social ties	Colleagues' visible activity, out-of-office replies, conference conversations
Language and locale	Country and language settings
Physical presence	Site visits, courthouse terminals, sign-in sheets

Note how many are non-technical. Payments, records requests, and social ties attribute far more effectively than an IP address, and no browser configuration touches them.

1.9.3 The Aggregation Problem, Reversed

Chapter 2 taught the mosaic effect from the collector's side. It applies to you as well: individually innocuous traces combine into an attribution.

A worked example. A subject's marketing team notices, over three weeks:

Trace	Individually
Repeated visits from one address range	Could be anyone
The reverse DNS resolves to a professional services firm	A firm looked at us
Visits cluster between 09:00 and 17:00 in one time zone	Someone at work, in that region
A professional profile view from someone at that firm	A named person at that firm
A public records request naming their permits, disclosed to them by the county	Someone is examining our operations formally
A connection request from a firm employee to a former employee	The examination involves personnel

Any one of these is nothing. Together they identify the firm, the person, the timing, and the subject matter, and the subject can now infer the client from context.

The defensive lesson: attribution is prevented by reducing the number of independent trace types, not by hardening one of them.

1.9.4 Proportionate Measures

Threat level	Typical measures
Low (public records research, no adversarial subject)	Separate browser profile; no logged-in browsing of subject platforms; ordinary professional discretion
Moderate (subject may take defensive action if aware)	The above, plus archives instead of repeat live visits, VPN with recorded exits, no platform profile views, care with records request timing, no purchases from the subject, controlled internal circulation
High (subject is capable and motivated, or a person is at risk)	The above, plus separate devices or VMs, per-case compartmentation, strict communications discipline, organizational support, legal advice, and a written assessment of whether the work should proceed in this form at all

The high row's last clause is deliberate. Where the threat is genuinely high, the correct professional

answer is sometimes that the work needs a different structure, a different party, or authorities involved, rather than a more elaborate personal configuration.

1.9.5 What Not to Do

Do not	Why
Create false personas to reduce attribution	Rule 2 and Rule 9; it is a different activity with different rules
Circumvent your organization's controls	Policy violation, and it removes protections you depend on
Attempt to evade lawful process	Outside this course entirely and outside professional practice
Assume a tool makes you anonymous	No single measure does
Adopt measures you cannot sustain	Abandoned measures leave you unprotected and believing otherwise
Confuse discretion with concealment from parties entitled to know	Clients, courts, regulators, and your own organization are not adversaries

1.10 Metadata Protection

1.10.1 Two Directions

Chapter 3 covered metadata as a **source**: what you can learn from a file. This section covers it as an **exposure**: what your files reveal about you.

The same fields, read from the other side:

Field	What it reveals about you
Author, last modified by	Your name
Company	Your organization
Template	Internal document naming and structure
Creating application and version	Your software estate
Creation and modification times, total editing time	When you worked, and for how long
Revision count	How much the document changed
Tracked changes and comments	What you removed, and internal discussion
File paths in links and archives	Internal directory structure and usernames
Image GPS coordinates	Where a photograph was taken
Embedded thumbnails	The pre-crop version of an image
Email headers	Your infrastructure, client software, and internal

Field	What it reveals about you
	hostnames
PDF layers and hidden objects	Content you believed was removed

1.10.2 The Redaction Failure

The most consequential metadata exposure is not a metadata field at all. **Drawing a black rectangle over text in a PDF hides it visually and leaves the text in the file.** Anyone can select it, copy it, or extract it with ordinary tools.

The same class of error:

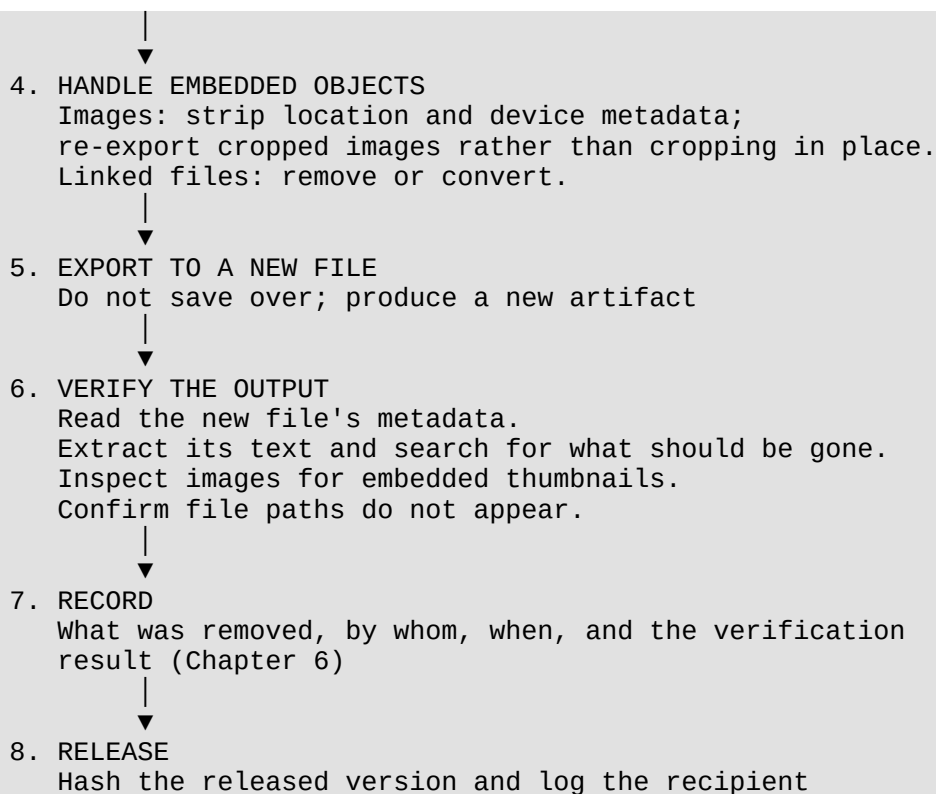
Apparent removal	What actually happens
Black box drawn over text	Text remains, selectable and extractable
White text on a white background	Text remains
Cropping an image in a document	The full image is frequently retained; only the display is cropped
Resizing an image to hide detail	Original resolution retained in some formats
Deleting a slide or hiding rows	Content may remain in the file
Accepting tracked changes visually without removing them	Change history remains
Flattening that is not actually flattening	Layers retained

True redaction removes the content and then produces a new file. The reliable pattern is: remove the content, export or print to a new file, verify by extracting text from the result, and confirm the extraction contains nothing that should be gone.

1.10.3 The Pre-Publication Workflow

Applies to anything leaving your control: a client report, a public advisory, a court exhibit, a press statement.

1. FINALIZE CONTENT
Editing complete
↓
2. REMOVE, DO NOT HIDE
Delete the content that must not appear.
Accept or reject all tracked changes.
Delete all comments.
Remove hidden rows, slides, and layers.
↓
3. STRIP DOCUMENT METADATA
Author, company, manager, template, editing time,
revision count, custom properties



Step 6 is the step that distinguishes a workflow from a hope. Producing a redacted file and not verifying it is how every published redaction failure has happened.

1.10.4 Metadata Hygiene During an Investigation

Not everything should be stripped. Evidence metadata is evidence.

Material	Position
Collected evidence	Never strip. Metadata is part of the item and Chapter 6 requires it preserved. Work from copies
Internal work product	Metadata is fine and frequently useful
Drafts circulated internally	Ordinary metadata is acceptable; be aware that "internal" circulation leaks
Anything sent to a client	Strip organizational and personal metadata beyond what is intended
Anything published	Full pre-publication workflow
Anything filed in a proceeding	Follow the tribunal's rules; frequently strict and specific
Images you produce	Strip location and device metadata unless they are the evidence

The distinction to hold onto: stripping metadata from evidence destroys evidence, and failing to strip it from a published product exposes you. The two operations happen to different files at different

points, and confusing them is a serious error in either direction.

1.10.5 Organizational Metadata Exposure

An investigator is not the only source of leaks from their organization.

Source	Exposure
Published documents across the organization's website	Author names, internal usernames, software estate, and internal paths, at scale
Job postings	Technology stack and internal structure (Chapter 3)
Out-of-office replies	Names, roles, delegation chains, and sometimes client names
Email signatures and headers	Internal hostnames and infrastructure
Public code repositories	Internal names, structure, and occasionally credentials
Conference presentations	Methods, tooling, and case detail

A periodic audit of the organization's own published files is a legitimate defensive exercise and is frequently revealing. It is the same technique from Chapter 3, pointed inward.

Part 2: Comparison Tables

2.1 Privacy vs. Anonymity vs. Confidentiality

Dimension	Privacy	Anonymity	Confidentiality
Definition	Control over who knows what about you	Your identity is not known in connection with an activity	The content of a communication or record is known only to authorized parties
Question answered	Who knows this about me?	Who is doing this?	What does it say?
What is hidden	Selected information	The actor	The content
What may still be visible	Your identity	The activity itself	Who communicated, when, and how much
Typical measures	Data minimization, access control, retention limits	Network routing, identity compartmentation, behavioural discipline	Encryption, access control, need to know
Achieved by	Choosing what to disclose and to whom	Removing linkage between actor and act	Restricting who can read

Dimension	Privacy	Anonymity	Confidentiality
Common failure	Aggregation defeating individually minor disclosures	A single logged-in session, or a behavioural leak	Correct encryption to the wrong party
For an investigator, defensively	Keeping your personal life separate from your work	Preventing a subject from identifying who is looking	Protecting case material, client identity, and sources
For an investigator, offensively	The subject's privacy constrains what you may collect (Ch.7)	Not a goal; you are not hiding from lawful process	Your obligation to the client and to third parties
Can you have one without the others	Yes: an anonymous message can be unencrypted; an encrypted message can be fully attributed		

2.2 Standard vs. Private Browsing vs. Browser Isolation

Dimension	Standard browsing	Private / incognito mode	Separate browser profile	True isolation (VM, container, remote browser)
Local history saved	Yes	No	Yes, in that profile	Yes, inside the environment
Cookies separated from personal session	No	Temporarily	Persistently	Completely
Logged-in state separated	No	Yes, for the session	Yes, persistently	Yes
Extensions separated	No	Usually disabled by default	Yes	Yes
IP address changed	No	No	No	No, unless combined with a network measure
Fingerprint changed	No	No	No	Partially, in a standardized environment
Protects against hostile content	No	No	No	Yes, this is its purpose
Visible to your network operator	Yes	Yes	Yes	Yes
Visible to the site	Fully	Fully	Fully	The environment is

Dimension	Standard browsing	Private / incognito mode	Separate browser profile	True isolation (VM, container, remote browser)
you visit				visible, not your machine
Setup effort	None	None	Minutes	Moderate to high
Sustainability	High	High	High	Moderate
Evidence capture quality	Best	Good	Good	Variable; transfer friction
Right use	Ordinary personal browsing	A single low-sensitivity lookup	The default for investigative work	Hostile content, or high threat models
Chief misconception		That it provides anonymity	That it changes your IP	That it is primarily an anonymity measure

2.3 Physical Computers vs. Virtual Machines vs. Containers

Dimension	Physical machine	Virtual machine	Container
Isolation boundary	Hardware	Hypervisor; separate kernel	Shared host kernel
Isolation strength	Strongest	Strong	Moderate
Cost	High	Low, once the host exists	Very low
Startup	Minutes	Tens of seconds	Seconds
Snapshot and rollback	Impractical	Native, fast, and the key feature	By rebuilding from an image
Disposability	Poor	Excellent	Excellent
Full desktop environment	Yes	Yes	Rarely
Changes your network identity	No	No, by default	No
Suitable for browsing investigations	Yes	Yes, the usual answer where isolation is needed	Rarely
Suitable for hostile content	Yes, if rebuilt or air-gapped	Yes, with snapshot discipline	No
Suitable for reproducible tooling	Yes	Yes	Yes, its strength
Escape risk	Physical compromise	Rare but real	Higher than a VM

Dimension	Physical machine	Virtual machine	Container
Common failure in practice	Becomes a second unmanaged machine	Never snapshotted; accumulates personal use	Treated as a security boundary it is not
Management overhead	High	Moderate	Low
Permitted on managed corporate devices	Usually	Frequently not without approval	Frequently not

2.4 VPNs vs. Tor vs. Direct Connections

Dimension	Direct connection	VPN	Tor
What the site sees	Your address	The VPN server's address	An exit relay's address
What your network operator sees	Your destinations	That you use a VPN, and volume and timing	That you use Tor, and volume and timing
Who can see both ends	Your operator, partially	The VPN provider	No single relay, by design
Trust required in	Your network operator	The VPN provider, substantially	The network design, and no single relay
Speed	Fastest	Fast	Slow
Site accessibility	Best	Good; some blocking and additional verification	Frequently blocked
Geographic consistency	Your actual location	The chosen exit, consistent	Varies unpredictably
Evidence capture suitability	Best	Acceptable, with the exit recorded	Poor
Protects against fingerprinting	No	No	Partially, in the standard configuration
Protects a logged-in session	No	No	No
Cost	None	Subscription	Free
Institutional policy	Usually required	Frequently restricted	Frequently prohibited
Appropriate for	Ordinary records research	Preventing organizational attribution in a subject's analytics	Censorship circumvention; source protection with organizational support
Not appropriate for	Work where the subject's analytics matter	Anonymity; circumventing employer controls	Volume investigative work; evidentiary capture

Dimension	Direct connection	VPN	Tor
Chief misconception	That nobody sees it	That it makes you anonymous	That it protects against self-inflicted disclosure

2.5 Personal Identity vs. Compartmentalized Investigative Identity

Dimension	Personal identity	Compartmentalized investigative identity	False persona (prohibited)
What it is	You, as you exist	A separate professional account set used for investigative work	A fabricated identity presenting as someone who does not exist
Claims to be	You	Nothing in particular; a work account	A specific kind of person, or a specific person
Purpose	Living	Separating personal life from professional work; limiting blast radius	Obtaining access or information not otherwise given
Accuracy of information given to services	Accurate	Accurate	False
Permitted in this course	Yes, for personal use	Yes	No. Rule 2 and Rule 9
Typical components	Personal email, personal profiles, personal devices	Work email address, work subscriptions, work browser profile, work device or VM	Fabricated name, invented history, false profile
Links to guard	Recovery details, shared devices, reused passwords	Recovery details, behavioural patterns, timing, device sharing	Not applicable
What it protects	Nothing, by itself	The investigation, the client, colleagues, and your own privacy	Nothing legitimate
Failure mode	Personal life attached to professional work	Recovery-detail linkage; behavioural crossover	Discovery, and the consequences Chapter 7 describes
Cost	None	Administrative overhead; sustainable at moderate levels	Legal and professional exposure

2.6 Encrypted vs. Unencrypted Communications

Dimension	Unencrypted	Encrypted in transit	End-to-end encrypted
Readable by an	Yes	No	No

Dimension	Unencrypted	Encrypted in transit	End-to-end encrypted
intermediate network			
Readable by the service operator	Yes	Yes	No
Readable by a party compelling the operator	Yes	Yes	Content, no; metadata, usually yes
Metadata visible to the operator	Yes	Yes	Yes
Protects against a compromised endpoint	No	No	No
Protects against an unencrypted backup	No	No	No
Requires verification to be meaningful	Not applicable	Server identity is verified by certificate	Yes: the correspondent's key must be verified
Typical examples	Plain email between unrelated providers; SMS	Most web traffic; most email in transit between servers	Certain messaging applications; explicitly end-to-end encrypted services
Appropriate for case material	No	Only with additional controls	Yes, with verification and endpoint discipline
Chief misconception		That "encrypted" means the operator cannot read it	That it protects metadata, endpoints, or recipients' behaviour

2.7 Metadata Types and Their Investigative Value

Metadata type	Where it lives	Value to an investigator (offensive)	Exposure to you (defensive)
Document properties	Word processing, spreadsheet, presentation files	Author, organization, template, editing time, revision count	The same fields identify you and your organization
Tracked changes and comments	Office documents	What was removed and internal discussion	The most damaging accidental disclosure in ordinary documents
PDF properties and structure	PDFs	Creating application, producer, timestamps, layers	Reveals your software estate and workflow
Hidden PDF content	PDFs	Text under redaction boxes; deleted-but-retained objects	The classic published redaction failure

Metadata type	Where it lives	Value to an investigator (offensive)	Exposure to you (defensive)
Image EXIF	Photographs	Camera, settings, timestamps, GPS, serial numbers	Location and device disclosure
Embedded thumbnails	Images	The pre-crop version of an image	Content you believed cropped out
File system timestamps	Any file	Creation, modification, access patterns	Your working schedule
Archive structure	Zip and similar	Original paths and usernames	Internal directory structure and account names
Email headers	Messages	Originating infrastructure, relay path, client software	Your organization's infrastructure
Communications metadata	Any messaging	Who, when, how often, how much	The relationship map, frequently the whole finding
Web page structure	HTML, scripts, analytics IDs	Shared analytics identifiers linking sites	Your own site's identifiers linking your properties
Network metadata	Traffic	Destinations, timing, volume	Your interest and schedule

2.8 Common OPSEC Mistakes and Their Consequences

Mistake	How it happens	Consequence	Prevention
Browsing a subject while signed in to a personal account	Habit; a single wrong window	Direct identity disclosure to the subject; defeats every other measure	Separate browser profile; never sign in there
Repeated live visits to the subject's site	Convenience during collection	A visible pattern in their analytics, with organizational attribution	Use archives (Ch.3); space out visits when live access is needed
Viewing a subject's profile on a platform that notifies	Ordinary research behaviour	The subject is told, by name in some configurations	Know which platforms notify; decide in advance
Assuming a VPN provides anonymity	Marketing	Continued exposure through sessions, fingerprint, and behaviour, with false	Understand the trust shift; layer measures to the threat model

Mistake	How it happens	Consequence	Prevention
		confidence	
Using a personal device "just once"	Deadline pressure	Contaminates every separation you built	Device discipline written into the plan
Shared recovery phone or email across compartments	Account setup convenience	Two "separate" identities are trivially linked	Recovery detail audit at account creation
Reusing an image or username across contexts	Convenience	Reverse image search or username search links the contexts	Unique per context; never reuse
Metadata in a delivered report	No pre-publication workflow	Author, organization, template, internal paths, and editing history disclosed to the recipient	Pre-publication workflow with verification
Black-box redaction in a PDF	Assuming visual removal is removal	Full text extractable by anyone; the most public class of failure	Remove content, export new file, verify by extraction
Cropping an image in place	Assuming the crop is destructive	Original retained; embedded thumbnail may show the full frame	Re-export cropped images as new files
Pasting a subject URL into a chat	Ordinary collaboration	Link preview fetches the URL, notifying the subject's server	Disable previews, or share the URL in a form that does not resolve
Submitting a subject URL to a public scanning service	Wanting a quick check	The submission becomes discoverable, revealing your interest	Understand which services publish submissions
Out-of-office reply naming a client	Automatic	Client relationship disclosed to anyone who emails	Generic replies; no client names in automation
A VM that is never rebuilt	Neglect	Accumulates personal use and traces; becomes a second unmanaged machine	Snapshot and rollback policy
Over-engineering the posture	Enthusiasm	Measures abandoned under pressure, silently, leaving no protection	Threat model first; cheapest effective measures
Circumventing employer controls	Believing it is good practice	Policy violation; loss of protections; possible dismissal	Choose measures with the organization, not around it
Discussing the case socially	Human behaviour	Attribution through social ties; the least	Naming discipline; case designations

Mistake	How it happens	Consequence	Prevention
		technical and most common leak	

2.9 Strengths, Limitations, and Appropriate Use Cases for Each Technique

Technique	Strengths	Limitations	Appropriate use	Not appropriate for
Separate browser profile	Free, fast, sustainable, prevents the worst failure	No IP or fingerprint change	The default for all investigative work	Anonymity; hostile content
Private browsing	Zero effort; clean session	Local only	A single low-sensitivity lookup	Anything the site can see
Virtual machine	Strong isolation, disposable, snapshot and rollback	No network identity change; overhead; may be prohibited on managed devices	Hostile content; strong separation; per-case environments	Changing what a site sees about your location
Container	Reproducible, cheap, fast	Shared kernel; weak boundary against hostile content	Tooling reproducibility	Isolation from hostile content
Remote browser isolation	Content never touches your machine; centrally managed	Provider sees everything; capture friction; addresses may be blocked	Organizational deployment; malware-adjacent work	Personal anonymity
VPN	Changes what the site sees; protects on untrusted networks	Trust shifts to the provider; no anonymity; content varies by exit; blocking	Preventing organizational attribution in a subject's analytics	Anonymity; evading employer controls; representative evidentiary capture
Tor	No single party sees both ends; strong against local observation	Slow; widely blocked; unpredictable geography; self-disclosure defeats it	Censorship circumvention; source protection with organizational support	Volume work; evidence capture; anything Rule 4 prohibits
Compartmentalized identity	Limits blast radius; separates personal from professional	Administrative overhead; behavioural leaks; recovery-detail linkage	All professional investigative work, at the level the threat model justifies	Obtaining access; misrepresenting yourself to a service

Technique	Strengths	Limitations	Appropriate use	Not appropriate for
End-to-end encrypted messaging	Operator cannot read content	Metadata visible; endpoints and backups unprotected; requires verification	Case discussion, source contact, client sensitive exchange	Protecting the fact that you communicated
Metadata stripping	Prevents author, organization, and internal structure disclosure	Must never be applied to evidence; requires verification	Anything leaving your control	Collected evidence, which must retain its metadata
Archived pages instead of live visits	Removes repeat-visit patterns; improves evidence	Coverage gaps; capture intervals	Most subject-site research	When only the live current state matters
Threat modelling	Makes every other choice proportionate	Requires honest assessment; easy to skip	Every investigation, before any measure is chosen	Nothing; it is always appropriate

Part 3: Case Studies

Each case sets out the OPSEC measures used, the risks identified, the protective decisions, the lessons, and how the posture contributed to the outcome. Cases marked *historical* describe documented patterns in general terms; cases marked *composite* are built from professional practice and are not real organizations or people.

3.1 Cybersecurity Investigation: Researching Attacker Infrastructure

(*composite*)

The situation. A security team is investigating a phishing campaign targeting their organization. They need to examine the attacker's infrastructure: the phishing pages, the domains, the hosting, and any related sites.

Risks identified.

Risk	Assessment
Visiting the phishing pages from a corporate address tells the attacker they have been detected	High likelihood, moderate consequence: the attacker rotates infrastructure and the investigation restarts

Risk	Assessment
The pages may serve malicious content to visitors	Moderate likelihood, high consequence
Interacting with the pages may submit data or trigger a response	Moderate
Submitting the URLs to a public scanning service makes the interest discoverable	High likelihood, moderate consequence
Corporate reverse DNS names the organization directly	Certain

Measures adopted.

1. A dedicated VM, snapshotted clean, rebuilt after each session with hostile content.
2. A VPN with a recorded exit, so the corporate address does not appear in the attacker's logs.
3. Passive sources first: certificate transparency, passive DNS, and registration records (Chapter 3), which reveal the infrastructure without touching it.
4. A rule that no page would be interacted with: no form submission, no clicking through, no downloading beyond what was required to characterize the page.
5. Public scanning services used only after the team decided that the disclosure of interest was acceptable, and never for infrastructure whose operator was likely watching.
6. All captures logged with the exit location, VM state, and configuration, per the Section 1.1.7 rule.

Protective decisions. The decision that mattered most was **passive first**. Roughly 80% of what the team needed came from records that never touched the attacker's servers. Live visits were reserved for the specific questions passive sources could not answer.

Outcome. The campaign's infrastructure was mapped, additional domains were identified before they were used, and detection rules were deployed. The attacker showed no sign of rotating infrastructure during the investigation, which the team took as evidence that their presence had not been noticed.

Lessons.

Passive collection is an OPSEC measure, not only an efficiency one. Every question answered from a record is a question that did not generate a trace.

The scanning service disclosure is routinely forgotten. Submitting a URL to a public service makes your interest discoverable by anyone querying that service, including the operator of the infrastructure.

A VM plus a VPN is the standard posture for this work, and neither alone is sufficient: the VM handles hostile content, the VPN handles attribution.

3.2 Investigative Journalism: Protecting a Source

(historical pattern, described in general terms)

The situation. A reporter is working with a source inside an organization. The source's employment, and in some environments their liberty, depends on not being identified.

Risks identified.

Risk	Assessment
Communications metadata linking the reporter and the source	The primary risk; content encryption does not address it
The organization's internal monitoring detecting contact	High in a monitored environment
Documents provided by the source carrying identifying metadata	High and frequently overlooked
Publication detail narrowing the set of people who could have known	The classic source-burning mechanism
The reporter's own devices and accounts	Moderate
Newsroom colleagues' incidental disclosures	Moderate and underestimated

Measures adopted.

1. First contact through a channel the source chose, from a device and network not associated with their employer.
2. End-to-end encrypted messaging with verified keys, re-verified after any key change notification.
3. Compartmented handling in the newsroom: minimal access, no case name in general communications, a designation rather than a name.
4. **Metadata stripping on every document received**, before circulation, with the originals preserved separately under custody.
5. Editorial review of publication detail specifically for source-narrowing: could the set of people with access to this fact be small enough to identify?
6. No storage of contact details in synchronized address books.
7. A written agreement with the source about channels, timing, and what would happen if contact was lost.

Protective decisions. Two mattered most. **Publication detail review** is the measure that most often saves a source, because the reporting itself, not the communications, is what typically narrows the field. And **metadata stripping of received documents before internal circulation** prevented a document's author field from identifying the source to the newsroom, let alone to a publisher.

Outcome. Publication proceeded. The source was not identified. A subsequent internal inquiry at the organization examined document access logs and did not narrow the field, because the published detail had been deliberately generalized.

Lessons.

Metadata is the source's biggest risk, not interception. A document's author field, editing history, or printer identifiers have identified sources repeatedly.

Publication detail is an OPSEC decision. A specific figure quoted verbatim can identify who had access to it.

Compartmentation inside your own organization is legitimate and necessary, and it is uncomfortable, and it is not distrust of colleagues.

3.3 Corporate Due Diligence: The Silent Approach

(composite)

The situation. An acquirer commissions diligence on a target ahead of an approach. If the target learns that it is being examined, its negotiating position improves and it may seek other bidders.

Risks identified.

Risk	Assessment
Repeated visits to the target's website from one address range	High likelihood; the target's marketing team watches analytics
Professional profile views notifying target employees	High likelihood in default configurations
Public records requests disclosable to the subject	Certain in some jurisdictions
Purchases from the target creating a customer record	Moderate
The diligence firm's own staff discussing the mandate	Moderate
Out-of-office replies naming the client	Moderate
Metadata in the delivered report naming the acquirer	High consequence if it reached the target later

Measures adopted.

1. Archived pages used for the target's website wherever possible; live visits limited, spaced, and made through a VPN with a recorded exit.
2. Platform browsing done without a logged-in session; no profile views of target employees at all.
3. Records requests timed with counsel's advice, and where disclosure to the subject was likely,

either deferred or accepted as a known cost with the client informed in advance.

4. No purchases, no contact, no supplier enquiries.
5. A case designation used internally instead of the target's name; the client's name never in a subject line.
6. Pre-delivery metadata stripping on every report, verified.
7. A single point of contact with the client, and a written naming discipline.

Protective decisions. The records request timing decision was the one requiring real judgment: the records were valuable, and requesting them would probably tell the target. The team presented the trade-off to the client with a recommendation rather than deciding unilaterally, and the client chose to defer two of four requests until after the approach.

Outcome. The approach was made without prior awareness on the target's side. The two deferred requests were made after the approach, when disclosure no longer mattered, and produced findings used in negotiation.

Lessons.

Timing is an OPSEC measure. A trace that would be damaging in week two is harmless in week eight.

Some exposures cannot be prevented, only scheduled and disclosed. Presenting the trade-off to the client rather than absorbing it silently is the professional move.

Naming discipline inside the firm did more work than any technical measure, because the most likely leak was a conversation.

3.4 Academic Research: Studying Online Communities

(composite, reflecting documented research practice)

The situation. A research team studies an online community. Their concerns are the reverse of most cases in this chapter: they must protect participants, and they must also protect researchers from harassment, which is a documented occupational risk in some research areas.

Risks identified.

Risk	Assessment
Researcher identification leading to harassment	Moderate to high in some subject areas
Institutional affiliation exposing the university to pressure	Moderate
Participant identification through quotation	High, and covered in Chapter 7
Researcher accounts being linked to personal accounts	Moderate

Risk	Assessment
Data holdings being compromised	Moderate, high consequence
Metadata in published papers and datasets	Moderate

Measures adopted.

1. Institutional accounts, not personal ones, for all research activity, with the institution's knowledge.
2. Observation from accounts that do not misrepresent identity; where the platform requires an account, an accurate institutional research account, disclosed to moderators where the study design called for it.
3. Encrypted storage for the dataset, access limited to the named research team, with retention aligned to the ethics approval.
4. Pseudonymization at collection and no verbatim quotation, following the Chapter 7 reasoning.
5. Pre-publication metadata stripping on the paper and any supplementary materials.
6. A team protocol for harassment: what to record, whom to notify, and when to involve the institution's security function.
7. No researcher's personal accounts used or referenced in any research context.

Protective decisions. The decision not to create observation accounts that concealed the research purpose was made at the ethics stage, and it cost the team access to parts of the community. The team accepted the cost, which is also the Chapter 7 position.

Outcome. The study completed. One researcher received hostile attention after publication, which the pre-agreed protocol handled without escalation, and no participant was identified.

Lessons.

OPSEC protects researchers, not only subjects, and research ethics discussions frequently omit this direction entirely.

A harassment protocol agreed in advance is worth more than any technical measure when the risk materializes, because it removes decision-making from a moment of stress.

Institutional accounts rather than personal ones is a simple measure that resolves several risks at once.

3.5 Incident Response: Investigating While the Adversary Is Present

(composite)

The situation. A company's incident response team is investigating an intrusion. The adversary still

has access, and the team must investigate without revealing that they have been detected.

Risks identified.

Risk	Assessment
The adversary reading the team's communications on the compromised network	High; this is the defining risk
Investigation activity visible in systems the adversary controls	High
The adversary destroying evidence or escalating on detection	High consequence
Ticketing and documentation systems on the compromised network	High
The team's own accounts being compromised	Moderate to high

Measures adopted.

1. **Out-of-band communications from the first hour:** a channel not dependent on the compromised environment, with participants verified individually.
2. Case documentation held outside the affected environment.
3. Investigation activity designed to be indistinguishable from normal administration where possible, with unusual queries batched and timed.
4. A written need-to-know list, deliberately short, with named exceptions.
5. No discussion of the incident in the company's ordinary channels, including in the physical office where the adversary might have obtained recordings.
6. A pre-agreed containment trigger, so that the decision to act was not made under pressure in the moment.
7. Evidence preservation per Chapter 6, executed before any containment.

Protective decisions. The out-of-band decision is the one that has to be made immediately or not at all. Teams that discuss an intrusion in the compromised environment's chat tool have, in documented cases, watched the adversary read the discussion and destroy evidence.

Outcome. The team mapped the intrusion over six days, preserved evidence, and executed containment at a pre-agreed point. The adversary showed no signs of anticipating containment.

Lessons.

Assume the environment is read by the adversary until proven otherwise. This is the incident response corollary of the whole chapter.

Out-of-band is a first-hour decision. It cannot be retrofitted after the discussion has already happened.

The need-to-know list is uncomfortable and necessary, and it should be written down, because informal need-to-know expands silently.

3.6 Digital Forensics: Handling and Analysis Discipline

(composite)

The situation. A forensic examiner receives a device for examination in a workplace matter. The examination must be defensible, must not alter the evidence, and must not leak either the fact of the examination or its contents.

Risks identified.

Risk	Assessment
Alteration of the evidence during examination	High consequence; defeats the entire exercise
Network connections from the examination environment reaching out	Moderate; can notify third parties or alter cloud state
Examination findings leaking within the organization	Moderate
Case material accumulating on general-purpose systems	Moderate
Third-party personal data on the device being examined beyond scope	High, and a Chapter 7 issue as much as an OPSEC one

Measures adopted.

1. Examination performed on a working copy, never the original, with hashes verified before and after (Chapter 6).
2. An examination environment isolated from the network, so that nothing reaches out during analysis and no cloud state is altered.
3. Scope-limited examination: search terms and date ranges defined in the plan, with anything outside scope recorded as encountered and not examined further.
4. Case material held in a dedicated encrypted store, access-controlled and logged.
5. Findings communicated only to the named recipients, out of band from the systems being examined.
6. Reporting stripped of metadata before delivery, with the originals retained under custody.

Protective decisions. Network isolation of the examination environment is the measure that distinguishes competent forensic practice, and it addresses an OPSEC risk that is not obvious: a device that connects during examination can synchronize, notify, or receive remote instructions, any of which alters the evidence and can reveal the examination.

Outcome. The examination was completed, the findings withstood challenge, and the scope discipline meant that a substantial volume of unrelated personal material on the device was never examined and never appeared in any report.

Lessons.

Isolation protects the evidence and the investigation simultaneously.

Scope discipline is an OPSEC measure as well as an ethical one, because material you never examined cannot leak from your report.

The Chapter 6 and Chapter 7 disciplines converge here, and a forensic examination is where a failure in any of the three chapters becomes visible at once.

3.7 Threat Intelligence: Sustained Collection Without Exposure

(composite)

The situation. A threat intelligence team maintains long-running collection against a set of threat actors, including monitoring of infrastructure and of forums where the team's own organization is occasionally discussed.

Risks identified.

Risk	Assessment
Sustained collection creating a recognizable pattern	High, because the collection is continuous
Attribution of the collection to the organization	High consequence: the organization becomes a target
Analyst identities being exposed	High consequence: personal risk
Collection infrastructure being identifiable as belonging to the organization	High
Silent breakage of automated collection (Chapter 4)	Moderate
Legal and policy limits on collection channels	Certain

Measures adopted.

1. Collection infrastructure separated from corporate infrastructure at the network level, with addresses not attributable to the organization.
2. Analysts never using personal accounts or devices for any collection activity.
3. Timing variation in automated collection, so that the pattern does not encode a working schedule.

4. Compartmentation between analysts and the collection infrastructure, so that a compromise of one does not expose the other.
5. Strict adherence to Rule 4 and the organization's legal boundaries: monitoring through commercial services and sharing arrangements rather than direct access to prohibited environments.
6. Periodic review of the organization's own public footprint, looking for the exposures described in Section 1.10.5.
7. A named security contact and a protocol for analysts who receive threats.

Protective decisions. The most significant was the decision not to conduct direct collection in environments where doing so would create legal and personal exposure, and instead to rely on commercial monitoring and sharing arrangements. It reduced capability and it removed a category of risk entirely, which is the Chapter 3 position on the dark web restated as an OPSEC decision.

Outcome. The programme ran for several years. Attribution of the collection to the organization did not occur. One analyst received hostile attention through their personal accounts, which the protocol handled, and the review that followed tightened the separation between personal and professional footprints.

Lessons.

Continuous collection creates patterns that episodic collection does not, and timing variation is a genuine measure rather than a refinement.

The analyst is part of the attack surface. A threat intelligence programme that protects its infrastructure and not its people has protected the wrong thing.

Declining a collection channel is an OPSEC decision, and it is frequently the strongest one available.

3.8 Cross-Case Comparison

Case	Primary risk	Decisive measure	What it cost
Attacker infrastructure	Alerting the adversary	Passive collection first; VM plus VPN for the rest	Slower; some questions unanswered
Source protection	Communications metadata and document metadata	Metadata stripping and publication detail review	Less specific reporting
Due diligence	Subject learning of the approach	Archives instead of live visits; timing of records requests	Two records requests deferred
Academic research	Researcher harassment and participant	Institutional accounts; no concealed	Reduced access to parts of the community

Case	Primary risk	Decisive measure	What it cost
	identification	observation; harassment protocol	
Incident response	Adversary reading the investigation	Out-of-band communications in the first hour	Coordination friction
Digital forensics	Evidence alteration and scope leakage	Network-isolated examination environment; scope discipline	Slower examination
Threat intelligence	Attribution and analyst exposure	Separated collection infrastructure; declining a collection channel	Reduced capability

Two patterns run through all seven. **In six of seven, the decisive measure reduced capability**, and in every case the team accepted that trade knowingly and wrote it down, which is what distinguishes a posture from a preference. And **in five of seven, the risk that mattered most was not technical**: metadata, timing, naming, publication detail, and social discussion did more damage than any network exposure would have.

Part 4: Chapter Summary

Operational security is identifying what your own activity reveals, assessing the risk, and applying proportionate measures. It is defensive throughout, and Rule 9 governs it: OPSEC never buys access, and the moment a measure's purpose becomes reaching something you could not reach as yourself, it has become circumvention rather than protection.

The OPSEC cycle runs from critical information through threats, vulnerabilities, and risk assessment to countermeasures and review. The step students skip is risk assessment, and skipping it produces both failure modes at once: elaborate protection against threats that do not exist alongside no protection against the one that does. A threat model answers four questions: what am I protecting, from whom, what can they actually do, and what happens if they succeed. Two investigations with different answers need entirely different postures, and applying one's measures to the other is a mistake in both directions.

Over-engineering is the more common student failure and it is dangerous because it feels responsible. Measures that cannot be sustained on the worst day of an investigation are abandoned silently, leaving no protection and a false belief in it. The correct posture is the cheapest set of measures that addresses the assessed threats and survives deadline pressure.

OPSEC fails at its weakest link, and the weakest link is rarely technical. Across every case study, the failure mode was a person doing an ordinary thing in the wrong context: a logged-in session, a

mentioned client name, a document's author field, a link pasted into a chat.

OPSEC and evidence quality can conflict, and the chapter takes that seriously. VPN exits change the content you receive, aggressive blocking breaks captures, and isolated environments complicate transfer. The rule is to record the configuration in every capture record and to prefer the configuration that produces the most representative capture unless the threat model requires otherwise.

Sites see more than students expect, and the most consequential exposure is the logged-in session, which defeats every technical measure instantly. Fingerprinting is real, rarely the binding constraint, and counterintuitive: heavy customization makes a browser more distinctive, not less. Private browsing is a local privacy feature that protects you from other people using your computer and provides almost nothing against the site you visit.

The highest-value measures are free. Never browsing subject targets while signed in to personal accounts, a separate browser profile, and using archives instead of repeated live visits address the exposures that actually occur, cost nothing, and are sustainable. Students consistently want to start with the expensive measures instead.

Virtual machines provide separation, disposability, snapshots, and containment, and they do not change your network identity. Containers share the host kernel and are excellent for reproducibility and unsuitable as a boundary against hostile content. The usual VM failure is neglect: never snapshotted, gradually accumulating personal use, becoming a second unmanaged machine.

A VPN changes who can see your activity rather than removing them. It replaces your network operator with the VPN provider, which is an improvement only if you trust the provider more and only against the adversary you actually have. It does not provide anonymity, does not change your fingerprint, does not protect a logged-in session, and can actively harm evidentiary capture through geographic content variation.

Tor routes through multiple relays so that no single relay sees both ends, which is its design property and the difference from a VPN. It is slow, widely blocked, geographically unpredictable, poor for evidentiary capture, and defeated entirely by self-disclosure. Rule 4 remains in force: understanding Tor is part of understanding the internet, and you will not use it to reach onion services in this course.

A compartmentalized investigative identity is not a false persona, and the distinction is the test of whether you have understood this chapter. Compartmentation separates your personal life from your professional work and limits blast radius; a false persona exists to be treated as someone you are not so that access is granted, and it is prohibited. Compartmentation is defeated most often by shared recovery details and by behavioural crossover in writing style, timing, interests, and reused images.

Secure communication is four properties, and authentication is the one investigators skip: an encrypted channel to the wrong party is worse than an unencrypted one because it feels safe. End-to-end encryption removes the operator from the set of readers and does not protect metadata, endpoints, backups, or recipients' behaviour. Every investigation needs a communications plan covering parties, channels, prohibited channels, verification, file sharing, device requirements, naming discipline, retention, and a compromise procedure.

Attribution is prevented by reducing the number of independent trace types, not by hardening one of them. Many of the strongest signals are non-technical: payments, records requests, social ties, out-of-office replies, and conference conversations attribute more effectively than an IP address, and no browser configuration touches them. The goal is preventing unnecessary attribution rather than invisibility, because a lawful investigator has no obligation to be invisible and elaborate anonymity can look worse than ordinary professional discretion.

Metadata runs in two directions. Chapter 3 treated it as a source; here it is an exposure, and the same fields that identify a subject identify you. The most consequential failure is not a metadata field at all: drawing a black box over text in a PDF hides it visually and leaves it extractable. True redaction removes content, exports a new file, and verifies by extracting text from the result. The pre-publication workflow ends in verification, and the step that distinguishes a workflow from a hope is checking the output.

Evidence metadata is never stripped. Stripping metadata from evidence destroys evidence; failing to strip it from a published product exposes you. The two operations apply to different files at different points, and confusing them is a serious error in either direction.

And across every case study, the decisive measure reduced capability, and the team accepted that trade knowingly and recorded it. Passive collection instead of live visits, deferred records requests, declined collection channels, generalized publication detail, and narrower examination scope each cost something. Writing the trade down is what makes a posture defensible rather than a preference.

Part 5: Key Terms

Grouped by theme. Terms carried from earlier chapters are marked and restated briefly.

5.1 Foundations

Operational security (OPSEC). The practice of identifying information about your own activity that an adversary could use, assessing the risk, and applying proportionate measures.

OPSEC cycle. Identify critical information, identify threats, analyse vulnerabilities, assess risk, apply countermeasures, review.

Critical information. The facts about your activity whose disclosure would harm the investigation, a person, or the organization.

Threat model. A written statement of what you are protecting, from whom, what they can do, and what it would cost if they succeeded.

Adversary capability. What a specific adversary can actually do, as distinct from what is imaginable.

Vulnerability. A trace your activity generates that an adversary could observe.

Countermeasure. A measure applied to reduce an assessed risk.

Proportionality (OPSEC sense). Matching the cost and burden of measures to the assessed risk.

Over-engineering. Applying measures beyond the threat model, which are abandoned under pressure and leave no protection.

Under-protection. Failing to apply measures the threat model requires.

Weakest link. The point at which a posture actually fails, which is usually behavioural, procedural, social, or documentary rather than technical.

Blast radius. The extent of what a single exposure reveals.

Compartmentation. Separating contexts so that an exposure in one does not reach the others.

Privacy. Control over who knows what about you.

Anonymity. The state of an activity not being connected to your identity.

Confidentiality. The state of content being readable only by authorized parties.

5.2 Browsing and Isolation

Browser fingerprinting. Identifying a browser by the combination of its observable characteristics rather than by a stored identifier.

Fingerprint distinctiveness. The property that unusual configurations are more identifiable, which makes heavy customization counterproductive.

Private browsing / incognito mode. A local privacy feature that prevents history retention and isolates cookies for a session, and provides almost nothing against the visited site.

Browser profile. A distinct browser context with its own cookies, storage, history, extensions, and signed-in state.

Session separation. Preventing investigative browsing from sharing signed-in state with personal browsing.

Synchronization. Browser account sync, which ties a profile to an identity and to other devices, and which is disabled in investigative profiles.

True isolation. Executing browsing in a separate environment so that content never runs on your machine.

Remote browser isolation. A service that runs the browser elsewhere and streams the rendered result.

Referrer. The page a request came from, which can disclose a search query or an internal page.

Prefetching. A browser fetching pages before the user requests them, generating traces for pages never visited.

Link preview fetching. A messaging or document application retrieving a URL to render a preview, notifying the destination server.

Reverse DNS. The name associated with an IP address, which frequently identifies an organization directly.

5.3 Environments

Virtual machine (VM). A complete simulated computer running as software on a host, with its own operating system.

Host and guest. The physical machine and the virtual machine running on it.

Hypervisor. The software that runs virtual machines and provides the isolation boundary.

Snapshot. A saved machine state that can be restored, which is what makes disposability practical.

Rollback. Restoring a snapshot, discarding everything since.

Disposability. The property that an environment can be destroyed and rebuilt without loss.

Container. An isolated process environment sharing the host kernel; strong for reproducibility, weak as a security boundary.

VM escape. A compromise crossing from a guest to the host; rare and not impossible.

Shared folders and clipboard sharing. Convenience features between host and guest that are the usual contamination path in both directions.

Air gap. Physical separation from any network.

5.4 Networks

Virtual private network (VPN). An encrypted tunnel to a provider's server, from which traffic emerges with that server's address.

Exit location. The geographic location of the server or relay from which your traffic reaches the destination, which affects the content you receive.

Trust shift. The principle that a VPN changes who can see your activity rather than removing them.

DNS leak. Name resolution occurring outside the tunnel, exposing destinations the VPN was expected to protect.

Fail open / fail closed. Whether traffic continues unprotected or is blocked when a tunnel drops.

Tor. A network routing traffic through multiple volunteer relays with layered encryption so that no single relay sees both ends.

Relay (entry, middle, exit). The three hops of a standard Tor circuit, each seeing only part of the path.

Traffic correlation. Deanonimization by an adversary observing both ends of a network.

Onion service. A service reachable only through the Tor network; out of scope under Rule 4.

Self-deanonimization. Defeating network protection through content, sessions, or behaviour.

5.5 Identity

Compartmentalized investigative identity. A separate professional account set used for investigative work, which does not misrepresent who you are.

False persona. A fabricated identity presenting as someone who does not exist or as someone else; prohibited by Rules 2 and 9.

Per-case compartmentation. Separate accounts and profiles per investigation so cases cannot be linked.

Recovery-detail linkage. Two apparently separate accounts linked by a shared recovery email or phone number; the most common silent failure of compartmentation.

Credential reuse. Using the same password across contexts, which links them on breach.

Multi-factor authentication. Requiring a second factor beyond a password; phishing-resistant forms are preferred.

Behavioural compartmentation. Preventing writing style, timing, interests, characteristic errors, and reused images from linking contexts.

Account register. A documented inventory of the accounts an investigation uses, with a closure plan.

5.6 Communications

Encryption in transit. Protection of data moving between a client and a server, readable by the server operator.

Encryption at rest. Protection of stored data, readable by anyone with the key or an unlocked device.

End-to-end encryption (E2EE). Encryption where only the endpoints hold keys, removing the operator from the set of readers.

Authentication (communications). Establishing that the party you are encrypting to is who you believe.

Key verification. Comparing a safety number or fingerprint through a channel independent of the one being verified.

Key change notification. An alert that a correspondent's key has changed, requiring re-verification.

Communications metadata. Who communicated with whom, when, how often, and how much, which is visible to operators regardless of content encryption.

Out-of-band communication. Communication through a channel independent of the environment under investigation.

Naming discipline. Rules about whether clients, subjects, and cases may be named in messages and subject lines.

Case designation. A neutral label used in place of a client or subject name.

Compromise procedure. The pre-agreed response to a lost device, a taken-over account, or a misdirected message.

Production log (Ch.6). The record of every copy of material provided to any recipient.

5.7 Attribution and Metadata

Attribution (defensive sense). An observer connecting activity to a person or organization.

Unnecessary attribution. Attribution that serves no legitimate purpose and harms the investigation, as distinct from lawful accountability.

Attribution signal. Any observable that contributes to connecting activity to an actor.

Timing pattern. Activity distribution that reveals a working schedule, therefore a time zone and frequently an organization.

Aggregation (defensive sense). Individually innocuous traces combining into an identification, the mosaic effect applied to the investigator.

Passive collection. Obtaining information from records rather than by touching the subject's infrastructure; an OPSEC measure as well as an efficiency one.

Public scanning service disclosure. The effect of submitting a URL or file to a public service, which makes the submission discoverable.

Document metadata (Ch.3). Author, organization, template, application, timestamps, editing time, and revision count embedded in files.

Tracked changes and comments. Retained edit history and internal discussion in office documents.

Redaction failure. Visually obscuring content that remains extractable in the file.

True redaction. Removing content and producing a new file, then verifying by extraction.

Metadata stripping. Removing embedded metadata before release; never applied to evidence.

Pre-publication workflow. The sequence of removing, stripping, handling embedded objects, exporting, verifying, recording, and releasing.

Embedded thumbnail (Ch.3). A smaller preview retained inside an image file, which may show a pre-crop frame.

Organizational footprint audit. Reviewing an organization's own published files and postings for metadata and structural exposure.

Part 6: Knowledge Assessment

6.1 Short Answer (20 questions)

Answer in three to five sentences unless otherwise noted.

1. Define operational security and state the six steps of the OPSEC cycle.
2. Explain what a threat model contains and why two investigations may need entirely different postures.

3. Describe the two OPSEC failure modes and explain why over-engineering is dangerous rather than merely wasteful.
4. Explain why the weakest link in an OPSEC posture is rarely technical, with three examples.
5. Describe two ways in which OPSEC measures can conflict with evidence quality, and state the rule that resolves the conflict.
6. List six things an ordinary website observes about a visitor, and identify which is the most consequential.
7. Explain browser fingerprinting and why adding privacy extensions can make a browser more identifiable.
8. State four things private browsing does and four things it does not do.
9. Explain what a separate browser profile provides and what it does not, and list four disciplines that make it effective.
10. Distinguish virtual machines from containers on isolation strength, disposability, and suitability for hostile content.
11. Explain why a virtual machine does not change your IP address, and what does.
12. Explain the trust shift created by a VPN, and list four questions to ask about a provider.
13. Explain how Tor differs from a VPN in who can see both ends of a connection.
14. State four limits of Tor that matter for investigative work.
15. Distinguish a compartmentalized investigative identity from a false persona, and state the test.
16. Explain recovery-detail linkage and why it is the most common silent failure of compartmentation.
17. Distinguish encryption in transit, at rest, and end to end, and state what end-to-end encryption does not protect.
18. Explain why authentication is the communications property investigators most often skip, and what verification requires.
19. List six attribution signals, at least three of which are non-technical, and explain how they aggregate.
20. Explain the redaction failure, describe true redaction, and state the rule about evidence metadata.

6.2 Multiple Choice (15 questions)

1. Rule 9 states that: a) All investigative traffic must use a VPN b) OPSEC never buys access; a measure whose purpose is obtaining what you could not obtain openly is not OPSEC c) Anonymity is the goal of investigative OPSEC d) Personal devices may be used if encrypted

- 2.** The step of the OPSEC cycle most often skipped is: a) Identifying critical information b) Identifying threats c) Assessing risk d) Applying countermeasures
- 3.** The most consequential thing a website can observe about an investigator is: a) Their screen resolution b) Their user agent string c) Their logged-in session identity d) Their time zone
- 4.** Adding several privacy extensions to a browser typically: a) Reduces fingerprint distinctiveness b) Increases fingerprint distinctiveness, making the browser more identifiable c) Has no effect on fingerprinting d) Prevents fingerprinting entirely
- 5.** Private browsing mode primarily protects: a) You from the site you are visiting b) You from your network operator c) You from other people using your computer d) Your identity from platforms
- 6.** A virtual machine, by default: a) Changes the IP address seen by visited sites b) Uses the host's network connection, so sites see the same address c) Routes traffic through Tor d) Prevents fingerprinting
- 7.** Containers are unsuitable as a boundary against hostile content because: a) They start too quickly b) They share the host kernel c) They cannot run a browser d) They cannot be rebuilt from an image
- 8.** The most accurate statement about a VPN is that it: a) Makes you anonymous b) Changes who can see your activity rather than removing them c) Protects a logged-in session d) Prevents fingerprinting
- 9.** The design property distinguishing Tor from a VPN is that: a) Tor is faster b) No single relay sees both the origin and the destination c) Tor changes your browser fingerprint d) Tor prevents self-disclosure
- 10.** Creating a separate work email address for records subscriptions, giving accurate information to each service, is: a) A false persona b) Compartmentation, and permitted c) Prohibited by Rule 2 d) Only permitted with client consent
- 11.** Two apparently separate compartments are most often silently linked by: a) Different browsers b) Shared recovery email addresses or phone numbers c) Different time zones d) Separate devices
- 12.** End-to-end encryption does not protect: a) Message content from the service operator b) Message content in transit c) Communications metadata, endpoints, and backups d) Content from intermediate networks
- 13.** In incident response, the decision that must be made in the first hour is: a) Which forensic tool to use b) Out-of-band communications, independent of the compromised environment c) Whether to notify the regulator d) Whether to rebuild the VM
- 14.** Drawing a black rectangle over text in a PDF: a) Removes the text b) Leaves the text in the file, selectable and extractable c) Is acceptable if the file is then renamed d) Encrypts the text
- 15.** Metadata should never be stripped from: a) A published advisory b) A client report c) Collected evidence d) A press release

6.3 True or False (10 questions)

Mark true or false. For each false statement, write one sentence explaining what makes it false.

1. Private browsing mode makes you anonymous to the websites you visit.
 2. A separate browser profile costs nothing, takes minutes, and prevents the most consequential OPSEC failure.
 3. Clearing cookies changes your browser fingerprint.
 4. A VPN protects your identity even when you are signed in to an account on the site you are visiting.
 5. Using Tor is undetectable by your local network operator.
 6. Over-engineering an OPSEC posture is harmless because extra protection cannot hurt.
 7. A virtual machine that is never snapshotted or rebuilt still provides full disposability.
 8. Communications metadata is usually visible to a service operator even when content is end-to-end encrypted.
 9. Payments, records requests, and social ties can attribute an investigation more effectively than an IP address.
 10. Metadata should be stripped from every file before it leaves your control, including collected evidence.
-

Part 7: Critical Thinking Exercises

Each group targets one skill. Produce the artifact the exercise names.

Identifying OPSEC risks

7.1 An investigator researching a regional employer does the following in one afternoon: visits the employer's website eleven times from the office, views three employees' professional profiles while signed in, files a public records request naming the employer, and emails a colleague a link to the employer's careers page. List every trace generated, who can see each, and what the aggregate reveals.

7.2 Build a threat model for an investigation of your choosing, answering all four questions, and state the posture that follows. Then state what would change if the consequence of exposure went from commercial harm to physical risk to a person.

7.3 A team believes its OPSEC is strong: VMs, a VPN, encrypted messaging, and compartmented accounts. Identify five ways the posture could still fail, none of them technical.

Selecting appropriate privacy protections

7.4 For each, state the proportionate measure and justify it: (a) checking a company's published filings;

(b) examining a suspected phishing page; (c) monitoring a subject's public listings weekly for six weeks; (d) contacting a source who fears employer retaliation; (e) researching a competitor ahead of a confidential approach.

7.5 A colleague proposes that all investigative work be done through a hardened, heavily customized browser on an isolated VM behind two VPNs. Assess this against the two failure modes and recommend an alternative.

7.6 You have four hours to improve the OPSEC posture of a small team with no budget. List what you would do, in order, and state the exposure each item addresses.

Evaluating browser and network security choices

7.7 Compare, for a specific investigation you define: direct connection, direct connection with a separate profile, VPN with a separate profile, and a VM with a VPN. State what each does and does not address, and choose one with reasons.

7.8 Your capture of a subject's pricing page, taken through a VPN exit in another country, differs from what the client sees locally. Explain the problem, state how it should have been handled, and describe what you would record.

7.9 An organization requires all traffic to pass through its monitoring. An investigator proposes a personal VPN so that the subject cannot see the organization's address. Identify the conflict and describe two ways to resolve it properly.

Protecting investigative identities

7.10 Design a compartmentation scheme for a firm running six simultaneous investigations with three investigators. State the level, the accounts required, the linking risks, and the closure procedure.

7.11 An investigator's work account and personal account are technically separate. List six ways they could still be linked, and the control for each.

7.12 A client asks you to "set up an account that looks like a normal customer" to see a competitor's pricing portal. Write your response, applying Rules 2 and 9, and offer a lawful alternative.

Recommending secure communication methods

7.13 Write a communications plan for a four-person investigation with an external client and one confidential source, covering all ten elements from Section 1.8.5.

7.14 Your team uses an end-to-end encrypted messaging application and considers case discussion secure. Identify four exposures that remain and the mitigation for each.

7.15 A case file must be delivered to a client's counsel. Compare four delivery methods on confidentiality, integrity, auditability, and Chapter 6 compliance, and recommend one.

Identifying metadata exposure

7.16 You are about to deliver a report containing three screenshots, two charts exported from a

spreadsheet, and one photograph taken by a colleague. List every metadata exposure and the step that addresses each.

7.17 A published PDF has a section redacted with black boxes. Describe how you would test whether the redaction is real, what you would do if it is not, and what the publisher should have done.

7.18 Audit your own organization or institution's public website for the exposures in Section 1.10.5, without using automated tools, and report what a five-minute review reveals.

Improving an investigation's OPSEC posture

7.19 An investigation is three weeks in with no OPSEC measures. Describe what can still be improved, what cannot be undone, and what you would tell the client.

7.20 Write an OPSEC review checklist a team could run at each of Chapter 6's review points, in no more than twelve items.

7.21 Your posture requires a measure that will slow collection by 30%. Write the two paragraphs you would send the client explaining the trade-off and the recommendation, without either overstating the risk or minimizing the cost.

Part 8: Hands-On Lab Exercises

General Lab Guidance

Do not modify a machine you do not control. Every lab has a path requiring no installation, no administrative rights, and no network configuration changes. If you are on an employer or institutional device, use that path, and check policy before doing anything else.

Rules 1 through 9 apply. Rule 9 in particular: nothing in these labs is used to reach material you could not reach as yourself.

Labs 3 through 5 chain on one fictional investigation. Labs 1 and 2 are standalone.

Rubric scale. 0 to 4 per criterion: 4 professional, 3 competent, 2 developing, 1 attempted, 0 missing or fundamentally incorrect.

Lab 1: Building a Dedicated Investigation Workspace

Time required: 2 to 2.5 hours **Format:** Individual **Difficulty:** Foundational

Objectives

1. Configure a dedicated investigation workspace using browser profiles, or a virtual machine where permitted.
2. Document precisely what the workspace isolates and what it does not.

3. Write the operating discipline that makes the isolation effective.
4. Verify the isolation, rather than assuming it.

Prerequisites

- Sections 1.1 through 1.4, and comparison tables 2.2 and 2.3.
- A computer on which you are permitted to create a browser profile. **Track B below requires no changes at all.**

Choose a Track

Track	Requirement	Who it is for
A: Browser profile	Permission to create a browser profile	Most students. No installation, no administrative rights
B: Design only	Nothing	Students on locked-down devices. Design the workspace and complete every worksheet without building it
C: Virtual machine (optional extension)	A personal machine and permission to run virtualization software	Students with the equipment and the permission. Bonus credit only

Steps

Step 1 (20 min). Threat model on Worksheet 1A, using the four questions from Section 1.1.4, for a stated investigation of your choosing. Record what you are protecting, from whom, their capability, and the consequence. Then state the posture level (low, moderate, or high) that follows.

Step 2 (30 min). Design the workspace on Worksheet 1B before building anything: profile name and naming convention, which extensions and why each is necessary, synchronization setting, default search behaviour, what will and will not be signed in to, cookie and site data policy, and what happens at case end.

Step 3 (30 min, Track A). Build it. Create the profile, apply your design, and record each setting you changed. If a setting you planned is unavailable in your browser, record that and what you did instead.

Step 4 (25 min). Isolation verification on Worksheet 1C. **Do not use any subject site for this.** Verify against neutral, benign properties, or reason it through on Track B. For each claim, state how you verified it or how you would:

Claim	Verification approach
The profile has no signed-in personal session	Check the profile's account state and any signed-in service
Cookies do not cross between profiles	Sign in to a benign service in one profile and

Claim	Verification approach
	confirm the other does not share the session
History does not cross between profiles	Compare the two histories
Extensions are separate	Compare extension lists
The IP address is unchanged	Compare what a neutral address-reporting page reports in each profile
Autofill does not carry personal data	Check autofill entries in the investigation profile

Step 5 (20 min). Write the operating discipline on Worksheet 1D: minimum six rules, each with the exposure it addresses and the failure that occurs if it is broken. The rules from Section 1.3.2 are a starting point, not the answer.

Step 6 (20 min). Write the OPSEC advantages and limitations statement, one page. What does this workspace address, what does it explicitly not address, and what would you need to add for each escalation of the threat model.

Step 7 (optional, Track C bonus). Build the VM per Section 1.4.3, record the configuration decisions, take the clean snapshot, and document the rollback policy and the evidence transfer workflow.

Worksheet 1A: Threat Model

Question	Answer
What am I protecting?	
From whom, specifically?	
What can they actually do?	
What happens if they succeed?	
Posture level and reason	

Worksheet 1B: Workspace Design

Element	Decision	Reason
---------	----------	--------

Worksheet 1C: Isolation Verification

Claim	Verified how	Result	Notes
-------	--------------	--------	-------

Worksheet 1D: Operating Discipline

Rule	Exposure it addresses	Failure if broken
------	-----------------------	-------------------

Expected Outcomes

- A threat model with a **specific** adversary. "Hackers" is not an adversary; "the subject's marketing team, who watch their site analytics" is.
- A design produced **before** building, so that the build is executing a decision rather than clicking through settings.
- Synchronization disabled, and the reason stated: sync ties the profile to an identity and to other devices.
- Extensions minimized, with each remaining one justified. Students who install several privacy extensions should be able to explain the fingerprint distinctiveness trade-off from Section 1.2.2.
- **Verification actually performed or reasoned**, including the IP check, which should confirm that the profile does **not** change the address. Students who expect it to have not understood Section 1.3.2.
- Six-plus discipline rules including, at minimum, never signing in to a personal account in the profile and never using the profile for personal browsing.
- A limitations statement that is honest: this workspace addresses session, cookie, history, extension, and signed-in-state separation, and addresses nothing about IP address, fingerprint, network visibility, or a compromised host.

Discussion Questions

1. Which setting in your design turned out to be unavailable or different in practice, and what did you do?
2. Your profile does not change your IP address. Explain to a colleague why it is still the highest-value measure.
3. Which of your discipline rules is most likely to be broken under deadline pressure, and what would make it easier to follow?
4. What would you add if the consequence of exposure moved from commercial harm to risk to a person?

Grading Rubric: Lab 1 (52 points)

Criterion	Weight	4 points looks like
Threat model specificity	x3	A named adversary with a realistic capability assessment
Posture proportionate to the model	x2	Neither over-engineered nor under-protected
Design produced before building	x2	A recorded design, with reasons per element
Synchronization and extension	x2	Sync off with the reason;

Criterion	Weight	4 points looks like
decisions		extensions minimized and justified
Build record	x2	Every changed setting recorded, including unavailable ones
Verification performed or reasoned	x3	All six claims addressed, including the IP result
Operating discipline	x3	Six-plus rules with exposures and failure modes
Limitations statement honesty	x3	Explicitly names what the workspace does not address
Escalation path	x1	What would be added at each higher threat level
Track C extension (bonus)	+3	VM built, snapshotted, with rollback and transfer workflow documented

Total possible: 84 weighted, plus 3 bonus. Passing: 58.

Lab 2: Comparing Browsing and Network Configurations

Time required: 2 to 2.5 hours **Format:** Individual or pairs **Difficulty:** Intermediate

Objectives

1. Compare standard browsing, browser isolation, VPN use, and Tor across defined dimensions.
2. Document the strengths, limitations, and appropriate use cases of each.
3. Assess each configuration's effect on evidence quality.
4. Match configurations to threat models.

Prerequisites

- Sections 1.2 through 1.6, and comparison tables 2.2 and 2.4.
- **No configuration is required.** Track B provides the observations if you cannot or should not test.

Choose a Track

Track	Requirement
A: Observation	Permission to visit neutral, benign address-reporting and browser-property pages in different

Track	Requirement
	profiles. Do not use a VPN or Tor on a device or network where policy prohibits it. Compare only the configurations you may lawfully and properly use
B: Provided observations	Use the observation set in Section 8.2.1 and complete the same analysis. This is the default track and loses no marks

8.2.1 Provided Observation Set

Fictional but representative observations of what a neutral property-reporting page displayed under four configurations, from one machine on one afternoon.

Property	Standard browsing	Separate profile	VPN (exit: neighbouring country)	Tor
IP address reported	Corporate range	Corporate range, identical	Provider range	Exit relay range
Reverse DNS	Resolves to the firm's domain	Resolves to the firm's domain	Generic provider hostname	Generic relay hostname
Approximate location	City of the office	Same	Neighbouring country	Varied between sessions: three different countries in four attempts
User agent	Browser X, version 128, Windows	Identical	Identical	Standardized string, differs from the host browser
Time zone reported by the browser	Local	Local	Local	Standardized to a single zone
Language reported	Local	Local	Local	Standardized
Screen and window characteristics	Actual	Actual	Actual	Standardized to a common size
Cookies present from prior sessions	Many	None	Depends on profile used	None
Signed-in session detected on a test service	Yes	No	Depends on profile used	No
Page load time for a reference page	0.4 s	0.4 s	0.9 s	6.2 s
Sites presenting	0 of 10	0 of 10	3 of 10	7 of 10

Property	Standard browsing	Separate profile	VPN (exit: neighbouring country)	Tor
additional verification				
Sites blocking access entirely	0 of 10	0 of 10	1 of 10	4 of 10
Reference page content variation	Baseline	Identical	Prices and availability differ; language offered differs	Varied by session

Note the two bolded rows. The VPN changed the reported IP location while the browser continued to report the local time zone and language, which is a mismatch an observer can notice and is a well-known limitation of a network-only measure.

Steps

Step 1 (30 min). Complete Worksheet 2A: for each of the four configurations, what changed and what did not, across all thirteen properties. Use your own observations (Track A) or the provided set (Track B), and state which.

Step 2 (25 min). Threat coverage on Worksheet 2B. For each of these threats, state which configurations address it, partially address it, or do not: the subject seeing the firm's address; the subject linking two visits; the subject identifying the individual investigator; the local network operator seeing destinations; the VPN provider seeing destinations; hostile content reaching the machine; fingerprint-based linking.

Step 3 (25 min). Evidence quality assessment on Worksheet 2C. For each configuration: the effect on capture representativeness, the effect on completeness, what must be recorded in the capture record, and whether it is suitable for evidentiary capture.

Step 4 (25 min). Use case matching on Worksheet 2D. For six investigations you define, each with a one-line threat model, state the configuration you would use and why, and the configuration you would reject and why.

Step 5 (20 min). Write the comparison analysis, one page: which configuration provides the most protection per unit of cost for ordinary investigative work, which is most often chosen for the wrong reasons, and where the intuitive answer is wrong.

Step 6 (15 min). Policy check. Write the section of an investigation plan that states which configurations your organization permits, which require approval, and which are prohibited, and how an investigator would find out.

Worksheet 2A: Configuration Comparison

Property	Standard	Separate profile	VPN	Tor
----------	----------	------------------	-----	-----

Worksheet 2B: Threat Coverage

Threat	Standard	Profile	VPN	Tor	VM + VPN
--------	----------	---------	-----	-----	----------

Worksheet 2C: Evidence Quality

Configuration	Representativeness	Completeness	Must record	Suitable for evidentiary capture?
---------------	--------------------	--------------	-------------	-----------------------------------

Worksheet 2D: Use Case Matching

Investigation	Threat model (one line)	Configuration chosen	Why	Rejected and why
---------------	-------------------------	----------------------	-----	------------------

Expected Outcomes

- Recognition that **the separate profile changed nothing the site could see about the network** and changed everything about session state, which is the central lesson.
- Recognition that **the VPN changed the network and nothing else**, including the time zone and language mismatch, which is the second lesson.
- Recognition that **Tor's standardization is what provides fingerprint resistance**, and that the same standardization makes it obviously Tor.
- Evidence assessment concluding that standard and profile configurations are best for representative capture, VPN is acceptable with the exit recorded, and Tor is poor.
- Threat coverage showing that **no single configuration addresses all threats**, and that the strongest common answer for hostile content is a VM combined with a network measure.
- Use case matching in which at least one investigation correctly gets a direct connection, because most investigative work does not need anything more.
- A comparison analysis identifying the separate browser profile as the highest value per unit of cost, and the VPN as the measure most often chosen for the wrong reason (anonymity).

Discussion Questions

1. The VPN changed the reported location and not the time zone. What does an observer learn from that mismatch?

2. Tor blocked or challenged access on 11 of 10 attempts across two rows. What does that mean for a six-week collection effort?
3. Which configuration would you use to capture a subject's pricing page as evidence, and why is the most protective configuration the wrong answer?
4. Which configuration is most often selected for the wrong reason, and what is the right reason to select it?

Grading Rubric: Lab 2 (56 points)

Criterion	Weight	4 points looks like
Configuration comparison completeness	x3	All thirteen properties across four configurations, track stated
Profile finding articulated	x3	Session state changed, network unchanged
VPN finding articulated	x3	Network changed, everything else unchanged, mismatch noted
Tor finding articulated	x2	Standardization explained as both strength and signal
Threat coverage matrix	x3	Seven threats across five configurations, correctly assessed
Evidence quality assessment	x3	All four configurations, with what must be recorded
Use case matching	x3	Six investigations, at least one correctly needing nothing more than a direct connection
Comparison analysis	x2	Identifies value per cost and the common wrong reason
Policy section	x2	Permitted, approval-required, and prohibited, with how to find out

Total possible: 96 weighted. Passing: 66.

The Chained Case: The Northlight Review

Fictional in all respects.

The engagement. Your firm, Marchetti Ridge Advisory, has completed a procurement review for the Northlight Community Trust, a fictional charity managing residential property. The review examined 212 invoices from a contractor and found 14 unsupported, totalling GBP 61,000.

Where you are. The report is written. A summary version is due for publication on the Trust's website, and the full package is due to the Trust's counsel. The complainant is a Trust employee who has been promised that they will not be identified. Two individuals are named in the internal working documents.

What Labs 3 through 5 do. Lab 3 examines the files about to be released. Lab 4 designs the communications for the remainder of the engagement. Lab 5 assesses the whole engagement's OPSEC posture.

Lab 3: Metadata Review Before Publication

Time required: 2.5 to 3 hours **Format:** Individual **Difficulty:** Intermediate to advanced

Objectives

1. Identify metadata in documents, images, and PDFs.
2. Detect a redaction failure and understand why it occurred.
3. Assess the privacy and attribution risk of each exposure.
4. Produce a pre-publication metadata protection checklist.

Prerequisites

- Section 1.10, comparison table 2.7, and Chapter 3 Section 1.19.
- The **Chapter 8, Lab 3 file set** provided alongside this workbook.

8.3.1 The File Set

File	Intended destination
01_northlight-summary-REDACTED.pdf	Public website
02_northlight-appendix-b.pdf	Trust's counsel only
03_northlight-draft-summary.docx	Internal; the source of the summary
04_site-photo-larkfield.jpg	Public website, illustrating the summary
05_invoiced-value-chart.png	Public website

8.3.2 Examination Methods

Any of these is sufficient. All are built in or require nothing beyond a text editor.

To examine	Method
PDF properties	Open in a PDF reader and view Document Properties

To examine	Method
PDF text under a redaction	Select the text with your cursor and copy it, or use the reader's "select all" then paste into a text editor. A search function inside the reader also works
Office document properties	Open and view File, then Info or Properties
Office tracked changes and comments	Turn on display of markup and comments
Office document internals	A .docx is a zip archive: copy it, rename the copy to .zip, extract it, and read docProps/core.xml, docProps/app.xml, word/comments.xml, and word/document.xml in a text editor
Image metadata	Right-click, Properties, Details (Windows) or Get Info (macOS); or any metadata viewer
Image embedded thumbnail	A metadata viewer that displays or extracts the thumbnail

Record which method you used for each file. A method that exposes fewer fields is a coverage boundary, exactly as in Chapter 3.

Steps

Step 1 (15 min). Predict, before examining anything. On Worksheet 3A, write what you expect each file to contain and what you expect the risk to be. You will compare this in Step 7.

Step 2 (50 min). Examine every file and record every field on Worksheet 3B: file, field, value, and the method used. Record empty fields as empty; an absent field is information.

Step 3 (25 min). The redaction test. For 01_northlight-summary-REDACTED.pdf: select and copy the text of the whole page into a text editor, and compare what you can read on screen with what you extracted. Record the result on Worksheet 3C, including exactly what the redacted passages say and why this matters given the promise made to the complainant.

Step 4 (30 min). Risk assessment on Worksheet 3D. For every exposure found: what it reveals, about whom, to whom, the harm if published, and the severity. Distinguish exposures about the firm from exposures about individuals, and mark any exposure that concerns a person who was promised protection.

Step 5 (25 min). Remediation on Worksheet 3E. For each exposure: the action required, who performs it, and how the remediation is verified. Then state, for each of the five files, whether it may be released as is, released after remediation, released only to a restricted recipient, or not released at all.

Step 6 (25 min). Build the pre-publication checklist. A reusable checklist your firm would apply to any release, following the Section 1.10.3 workflow, with a verification step for each item and a sign-off

block. Maximum two pages.

Step 7 (10 min). Compare against your Step 1 predictions and write a paragraph on what you did not expect.

Worksheet 3A: Predictions

File	Expected metadata	Expected risk
------	-------------------	---------------

Worksheet 3B: Metadata Inventory

File	Field	Value	Method used
------	-------	-------	-------------

Worksheet 3C: Redaction Test

Passage as displayed	Passage as extracted	Difference	Why it matters
----------------------	----------------------	------------	----------------

Worksheet 3D: Risk Assessment

Exposure	Reveals	About whom	To whom	Harm if published	Severity
----------	---------	------------	---------	-------------------	----------

Worksheet 3E: Remediation

Exposure	Action	Performed by	Verification	File disposition
----------	--------	--------------	--------------	------------------

Expected Outcomes

- **The redaction failure is the central finding.** The black boxes in file 01 hide nothing: the text extracts cleanly and discloses the contractor's name, **the complainant's name and department**, and two named individuals associated with the unsupported invoices. Given that the complainant was promised anonymity, this is the most serious exposure in the set and it would be irreversible on publication.
- **File 03 contains a tracked deletion and two comments.** The deleted sentence attributes personal approval to a named individual, and one comment records an instruction not to name the complainant, which is itself sensitive and would be embarrassing if released. The other comment records an internal disagreement about client pressure.
- **File 03's properties disclose** the firm name, a template name revealing internal document conventions, a manager's name, 487 minutes of editing time, 23 revisions, and internal keywords marking the document as a draft.
- **File 02 discloses an internal file server path**, revealing the firm's internal naming, a server

hostname, and the case's working directory. It is intended for counsel only, which reduces but does not eliminate the concern.

- **File 04 contains GPS coordinates**, a photographer's name, a camera serial number, a copyright field naming the firm, and **an embedded thumbnail showing a wider frame including an adjacent property** that the visible image excludes.
- **File 05 is the low-risk item**, which students should say explicitly rather than manufacturing a finding.
- **Dispositions** should conclude: file 01 not released in its current form under any circumstances, and re-produced by removing the content and exporting a new file, then verified by extraction; file 02 released to counsel only, after removing the path reference; file 03 not released at all, being an internal draft; file 04 released only after re-export with metadata stripped and the thumbnail eliminated; file 05 released as is or after routine stripping.
- **The checklist** must include a verification step that extracts text from the produced file and searches for what should be absent. A checklist that ends at "strip metadata" has missed the lab.

Discussion Questions

1. The complainant was promised they would not be identified. Describe what publication of file 01 would have done, and whether it could be undone.
2. Why did the black boxes fail? Explain the mechanism to a non-technical colleague in three sentences.
3. File 03 is internal and was never intended for release. Why does it still matter?
4. The embedded thumbnail in file 04 shows more than the visible image. What class of error is this, and where else does it occur?
5. Which finding did your Step 1 predictions miss entirely, and why?

Grading Rubric: Lab 3 (72 points)

Criterion	Weight	4 points looks like
Predictions recorded before examination	x1	Written first, honestly compared
Metadata inventory completeness	x3	All five files, all available fields, methods recorded
Redaction failure detected	x4	Text extracted; the complainant's name identified as the critical disclosure
Redaction mechanism explained	x3	Visual obscuring versus content removal, explained clearly
Tracked changes and comments found	x3	Both comments and the deletion identified and assessed

Criterion	Weight	4 points looks like
Internal path disclosure found	x2	File 02's server path identified
Image exposures found	x3	GPS, photographer, serial, copyright, and the embedded thumbnail
Low-risk item identified	x2	File 05 stated as low risk rather than padded
Risk assessment quality	x3	Reveals, about whom, to whom, harm, severity; person-specific exposures flagged
Remediation and dispositions	x3	Per file, correct dispositions with verification
Pre-publication checklist	x4	Follows the workflow and ends in verification by extraction
Prediction comparison	x1	Honest account of what was missed

Total possible: 128 weighted. Passing: 88.

Lab 4: Secure Communications Plan

Time required: 2 to 2.5 hours **Format:** Individual **Difficulty:** Intermediate

Objectives

1. Design a communications plan covering authentication, encryption, account management, and file sharing.
2. Match channels to content categories with stated reasons.
3. Specify verification and compromise procedures.
4. Address the metadata exposure that encryption does not cover.

Prerequisites

- Section 1.8, comparison table 2.6, and Chapter 6 Section 1.7.
- Lab 3 complete.

The Situation

The Northlight engagement continues for four more weeks. The parties are:

Party	Role
You	Lead investigator, Marchetti Ridge Advisory
S. Okonkwo	Your firm's engagement manager
A junior analyst	Supporting collection and documentation
The Trust's general counsel	The client contact
The Trust's board chair	Receives the final summary only
The complainant	A Trust employee, promised anonymity, who may need to be contacted through counsel
The Trust's IT provider	Manages the Trust's email and file systems

Two constraints. The complainant is an employee of the client, and the client's IT provider administers the client's email, which means correspondence to a client address may be readable by people at the client organization. And the contractor under review provides services to the Trust and has staff on Trust premises.

Steps

Step 1 (20 min). Content categories on Worksheet 4A. Define five to seven categories of content this engagement generates, from routine scheduling through to anything concerning the complainant. For each: sensitivity, who may receive it, and the consequence of disclosure.

Step 2 (30 min). Channel matching on Worksheet 4B. For each category: the channel, the reason, and the prohibited alternatives. **Address the client-email problem explicitly:** correspondence to the client's own email system is readable by the client's IT administrators, which matters for anything concerning the complainant or the contractor.

Step 3 (20 min). Authentication and verification on Worksheet 4C. For each party: how their identity and any keys are verified initially, when re-verification occurs, and what happens on a key change notification. Include the parties you have never met in person.

Step 4 (25 min). Account and device requirements on Worksheet 4D: multi-factor authentication, device encryption, screen lock, personal device policy, synchronization settings, and what is prohibited. Include the junior analyst, who is the most likely weak point.

Step 5 (25 min). File sharing on Worksheet 4E. For each transfer that this engagement requires, specify the method, the encryption, the access expiry, the hashing and logging per Chapter 6, and the recipient record. Include the final report to counsel, the summary to the board chair, and any material to the complainant through counsel.

Step 6 (20 min). Naming discipline and metadata on Worksheet 4F: whether the client, the contractor, the complainant, and the case may be named in subject lines, message bodies, file names, and calendar entries; the case designation to be used instead; and the treatment of automatic replies and calendar visibility.

Step 7 (20 min). Compromise procedure on Worksheet 4G: what happens if a device is lost, an account is taken over, a message is sent to the wrong recipient, or the complainant's identity is inadvertently disclosed. For each: immediate actions, who is notified, in what order, and what is recorded.

Worksheet 4A: Content Categories

Category	Sensitivity	Who may receive	Consequence of disclosure
----------	-------------	-----------------	---------------------------

Worksheet 4B: Channel Matching

Category	Channel	Reason	Prohibited alternatives
----------	---------	--------	-------------------------

Worksheet 4C: Authentication

Party	Initial verification	Re-verification trigger	Key change response
-------	----------------------	-------------------------	---------------------

Worksheet 4D: Account and Device Requirements

Requirement	Applies to	Reason	Verified how
-------------	------------	--------	--------------

Worksheet 4E: File Sharing

Transfer	Method	Encryption	Expiry	Hash and log	Recipient record
----------	--------	------------	--------	--------------	------------------

Worksheet 4F: Naming Discipline

Element	May be named?	Where	Designation used instead
---------	---------------	-------	--------------------------

Worksheet 4G: Compromise Procedure

Event	Immediate actions	Notified, in order	Recorded
-------	-------------------	--------------------	----------

Expected Outcomes

- **The client-email problem must be addressed explicitly.** Anything concerning the complainant sent to a Trust email address is readable by the Trust's IT administrators, who are colleagues of the complainant. The correct handling routes such material outside the client's own systems, through counsel's independent channel or a client portal not administered by the

Trust's IT provider, and the plan says so with the reason.

- **The complainant category must be the most restricted**, with the fewest recipients and the strictest channel, and the plan should state that the complainant's identity is not to appear in any message on any channel.
- **Authentication must cover parties never met in person**, with a verification approach that does not rely solely on the channel being verified.
- **The junior analyst appears in the device requirements**, because the least experienced person with access is the realistic weak point, and the plan should include what they are told and how compliance is confirmed rather than assumed.
- **File sharing must include hashing and a production log**, connecting to Chapter 6 rather than treating delivery as an afterthought.
- **Naming discipline must cover calendar entries**, which students routinely forget and which are frequently visible across an organization.
- **The compromise procedure must include inadvertent disclosure of the complainant's identity**, with an honest procedure that includes notifying counsel promptly rather than attempting to contain it quietly.
- A plan that treats end-to-end encryption as sufficient, without addressing metadata, naming, endpoints, or the client-email problem, has missed the lab's point.

Discussion Questions

1. The client's IT administrators can read the client's email. How do you raise that with a client without implying distrust of their staff?
2. Which content category was hardest to assign a channel to, and why?
3. Your junior analyst is the realistic weak point. What did you do about it that does not depend on them remembering?
4. Encryption does not hide that you communicated with counsel three times on one day. When does that matter here?
5. If the complainant's identity were disclosed by accident, what would you do in the first ten minutes?

Grading Rubric: Lab 4 (60 points)

Criterion	Weight	4 points looks like
Content categories	x2	Five-plus, with sensitivity and consequence
Channel matching with reasons	x3	Each category matched, prohibited alternatives named

Criterion	Weight	4 points looks like
Client-email problem addressed	x4	Explicitly identified and routed around, with the reason stated
Complainant category restriction	x4	Most restricted; identity not to appear on any channel
Authentication and verification	x3	All parties, including those never met; independent verification
Key change response	x2	Specified, with re-verification
Account and device requirements	x3	Complete, including the junior analyst, with confirmation rather than assumption
File sharing with hashing and logging	x3	Chapter 6 integration, per transfer
Naming discipline including calendars	x3	All elements, with a case designation
Compromise procedure	x3	Four events, with ordered notification and recording
Metadata awareness	x2	Recognizes what encryption does not cover

Total possible: 128 weighted. Passing: 88.

Lab 5: OPSEC Assessment of an Investigation

Time required: 2.5 to 3 hours **Format:** Individual **Difficulty:** Advanced

Objectives

1. Assess an investigation's OPSEC posture across attribution, identity separation, communications, and metadata.
2. Identify weaknesses and rate them by likelihood and consequence.
3. Recommend proportionate improvements with an implementation order.
4. Distinguish what can still be fixed from what cannot be undone.

Prerequisites

- All of Part 1, and comparison tables 2.8 and 2.9.
- Labs 3 and 4 complete.

The Engagement Record

What actually happened during the Northlight review. Fictional.

#	Event
R1	The investigation began without a written threat model
R2	Research was conducted from the firm's office network throughout. The firm's reverse DNS resolves to <code>marchettiridge.example</code>
R3	The lead investigator used their normal browser profile for the first two weeks, then created a separate profile
R4	The contractor's website was visited 26 times over three weeks, all from the office
R5	The lead investigator viewed four contractor employees' professional profiles while signed in to their own account
R6	The junior analyst searched the contractor's name from a personal phone on the office wifi "to check something quickly"
R7	Case material was stored on the firm's file server in a folder named <code>Northlight - ProcurementReview</code>
R8	Email correspondence with the Trust used subject lines including "Northlight procurement review: contractor findings"
R9	Two calendar entries were created titled "Northlight / Bellwether findings call" and were visible to the whole firm
R10	The lead investigator's out-of-office reply during one week read: "I am away; for Northlight matters contact S. Okonkwo"
R11	A link to the contractor's website was pasted into the firm's internal chat, which generated a preview
R12	The complainant's name appeared in three internal emails and in the draft report
R13	The draft report was emailed to the client's general counsel at their Trust address
R14	The summary PDF was produced with black-box redactions and was two days from publication when Lab 3 examined it

#	Event
R15	The site photograph was taken by a firm employee on a firm camera and was not stripped
R16	A public records request naming the Trust's contracts was filed in week two; the jurisdiction discloses requests to affected parties
R17	No account register exists; the firm's subscriptions to two records services use one shared login
R18	The junior analyst's device has no screen lock configured
R19	The firm's website publishes a case studies page describing the type of work it does for charities
R20	Nothing was recorded about any of the above

Steps

Step 1 (20 min). Reconstruct the threat model that should have existed, on Worksheet 5A, using the four questions. State the posture level it implies. This is the baseline against which everything else is assessed.

Step 2 (45 min). Weakness identification on Worksheet 5B. For every item in the record: the weakness category (attribution, identity separation, communications, metadata, documentation, or none), what it exposes, to whom, likelihood, consequence, and a combined rating. Some items are not weaknesses, and saying so is graded.

Step 3 (25 min). Aggregation analysis on Worksheet 5C. Identify at least three combinations of items whose combined effect is worse than any component, following Section 1.9.3. State what each aggregate reveals.

Step 4 (25 min). Reversibility on Worksheet 5D. For each weakness: can it be remediated, mitigated, or is it done and unrecoverable? For anything unrecoverable, what is the residual exposure and who needs to be told.

Step 5 (30 min). Recommendations on Worksheet 5E. Prioritized, with implementation order. For each: the action, the weakness it addresses, the cost, who performs it, and the timeframe. **Include at least four actions that cost nothing.** Then state which three you would do first and why.

Step 6 (20 min). Write the assessment memorandum, one page, addressed to the firm's engagement manager: the overall posture rating, the three most significant weaknesses, what cannot be undone, what must be told to the client, and the recommended immediate actions.

Worksheet 5A: Reconstructed Threat Model

Question	Answer
----------	--------

Worksheet 5B: Weakness Register

#	Category	Exposes	To whom	Likelihood	Consequence	Rating
---	----------	---------	---------	------------	-------------	--------

Worksheet 5C: Aggregation

Combination	Combined effect	Rating
-------------	-----------------	--------

Worksheet 5D: Reversibility

#	Remediable / mitigable / unrecoverable	Residual exposure	Who must be told
---	--	-------------------	------------------

Worksheet 5E: Recommendations

Priority	Action	Addresses	Cost	Owner	Timeframe
----------	--------	-----------	------	-------	-----------

Expected Outcomes

- **The most severe single finding is R14**, the redaction failure, because it is two days from publication, it would disclose a complainant who was promised anonymity, and publication is irreversible. It should be rated highest and should be the first recommendation.
- **R12 combined with R13 is the second finding.** The complainant's name in internal emails is a firm-side exposure; the same name reaching the client's own email system, administered by the client's IT provider, is a disclosure to the complainant's own colleagues.
- **R5 is unrecoverable.** Profile views made while signed in have already notified those individuals, and no subsequent measure undoes it. Students must classify it as such.
- **R4 and R2 aggregate:** 26 visits from a range whose reverse DNS names the firm, over three weeks, is an attributable pattern. Combined with R16, a disclosed records request, the contractor and the Trust can both infer who is examining what and when.
- **R9 and R10 aggregate:** a calendar entry naming both the client and the contractor, visible firm-wide, plus an out-of-office reply naming the client, discloses the engagement to anyone inside the firm and to anyone who emails the investigator.
- **R6 is the personal-device failure**, and the phone was on the office wifi, so it did not even provide the separation the analyst imagined.
- **R11 caused a fetch** from the chat provider or the analyst's device to the contractor's server.
- **R17 is an account management failure** with a shared login, meaning attribution of records service activity to an individual is impossible.

- **R19 is not a weakness**, or is at most a minor one: a firm publishing the type of work it does is ordinary and unavoidable. Students who rate it highly are padding.
- **R20 is the finding that compounds all the others**: nothing was recorded, so the firm cannot say what happened, cannot advise the client accurately, and cannot demonstrate what it did about it.
- **At least four no-cost recommendations** should appear: stop signed-in profile viewing, adopt a case designation, fix the out-of-office and calendar entries, and begin recording decisions.
- The memorandum must state plainly that the client needs to be told about R14 and about the R12 and R13 combination.

Discussion Questions

1. R14 is two days from publication. What do you do in the next hour, and in what order?
2. R5 cannot be undone. How do you explain an unrecoverable exposure to a client without either minimizing it or catastrophizing?
3. Three of your recommendations cost nothing. Why were they not already in place?
4. R20 says nothing was recorded. Explain how that makes every other weakness worse.
5. Which item did you initially rate too high, and what corrected you?

Grading Rubric: Lab 5 (76 points)

Criterion	Weight	4 points looks like
Reconstructed threat model	x2	Specific adversaries; posture level justified
Weakness identification coverage	x3	All twenty items assessed, correctly categorized
R14 rated highest and prioritized	x4	Identified as the most severe and the first action
R12 and R13 combination identified	x4	Client-email disclosure to the complainant's colleagues recognized
R5 classified as unrecoverable	x3	Correctly identified as done and not undoable
Likelihood and consequence ratings	x3	Defensible and differentiated, not uniform
Aggregation analysis	x3	Three-plus combinations with combined effects
Non-weaknesses identified	x2	R19 correctly rated low; no padding
Reversibility assessment	x3	Correct classification; residual

Criterion	Weight	4 points looks like
		exposure stated
Recommendations with priority and cost	x3	Ordered, owned, timeframed, four-plus at no cost
R20 compounding effect recognized	x2	Documentation failure identified as multiplying the rest
Assessment memorandum	x3	Honest, prioritized, states what the client must be told

Total possible: 140 weighted. Passing: 96.

Part 9: Capstone Assignment

The Rivermouth Port Authority OPSEC Plan

Weight: 35% of chapter grade **Time required:** 6 to 9 hours **Format:** Individual **Deliverable:** A complete OPSEC plan, specified in Section 9.3

9.1 The Scenario

Everything below is fictional.

You have been engaged by the **Rivermouth Port Authority**, a public body, to conduct a lawful OSINT investigation. The engagement was arranged through the Authority's general counsel and is confidential within the Authority: only the general counsel, the chief executive, and the board chair know it exists.

The requirement. Over the past eight months, three of the Authority's competitive tenders have been won by the same bidder, **Ardent Marine Services**, in each case at a price marginally below the next bidder. The Authority wants to know, before its next tender closes in nine weeks, whether the public record supports a concern that tender information is reaching Ardent in advance.

What the investigation will involve.

Activity	Detail
Corporate records research	Ardent, its parent, its affiliates, and its officers, across three jurisdictions
Court and licensing records	In two countries
Public procurement records	The Authority's own published records and those of two peer ports
Website and archived-site research	Ardent's site, its parent's site, and archived

Activity	Detail
	versions
Technical footprint research	Domains, certificates, and hosting associated with Ardent
Imagery	Commercial satellite imagery of Ardent's facilities
Social and professional platforms	Ardent's corporate presence and the professional roles of named officers
Internal records	The Authority's tender files, provided by counsel
Interviews	Two Authority staff, arranged through counsel

The complications.

- Ardent has staff physically present at the Authority's premises under two current contracts.
- One of the Authority's own procurement staff may be a subject of the concern, and that person has access to the Authority's IT systems, including its email.
- The Authority's IT function is outsourced to a provider that also serves Ardent.
- Two of the jurisdictions involved have data protection regimes that may apply.
- The engagement is confidential within the Authority; only three people know.
- Your firm has four people who will touch this: you, an analyst, a records researcher, and a partner who reviews.
- The Authority's board meets in nine weeks and the report must be delivered a week before.

9.2 Guidance on the Substance

The defining feature of this engagement is that **the client's own environment may be compromised from the investigation's point of view**. A member of the client's staff may be a subject, that person has system access, and the client's IT function is shared with the subject company. An OPSEC plan that treats the client as a safe channel has failed before it starts.

The second feature is that **Ardent staff are physically present at the client's premises**, which makes physical and conversational exposure as important as anything technical.

The third is proportionality. This is a lawful commercial investigation with a nine-week deadline and four people. A plan that requires infrastructure nobody will build, or measures nobody will sustain, is worse than a modest plan that is followed.

Rules 1 through 9 apply throughout, and Rule 9 in particular: nothing in this plan may be a means of reaching material you could not reach as yourself.

9.3 What You Must Produce

A complete OPSEC plan, in nine parts.

Deliverable 1: Threat Model and Risk Assessment (18 points)

- Critical information: minimum eight items whose disclosure would harm the investigation, the client, or a person.
- Adversaries: minimum five, each specific, with an honest capability assessment. "Ardent" is not sufficiently specific; identify who within it and what they can actually observe.
- Vulnerabilities: minimum fifteen traces this investigation will generate, by activity.
- Risk assessment: likelihood and consequence for each vulnerability, with a combined rating and a stated method.
- A posture level for the engagement overall, and where any activity requires a different level.

Deliverable 2: Isolation Strategy (14 points)

- Browser and profile architecture: how many profiles, for what, per person.
- Whether virtual machines are used, for what, and the snapshot and rollback policy if so.
- Device policy, including personal devices and the physical premises question.
- What each layer addresses and, explicitly, what it does not.
- The evidence quality impact of each isolation decision, and what must be recorded in capture records (Section 1.1.7).
- The path for team members on managed devices who cannot implement part of the strategy.

Deliverable 3: Network Strategy (10 points)

- The configuration for each activity type, with reasons: direct, VPN, or otherwise.
- Exit location decisions and their effect on the records and imagery you will retrieve.
- What is recorded in capture records.
- The position on Tor, with reasons.
- **The client-network question:** whether any work may be done from the Authority's premises or network, and why.
- Organizational policy compliance for your own firm.

Deliverable 4: Identity and Account Strategy (12 points)

- The compartmentation level chosen, with the reason.
- The account register: every account the engagement requires, its purpose, its owner, and its closure trigger.

- Linking risks and the control for each, including recovery details.
- **An explicit statement of the boundary**, with reference to Rules 2 and 9, and what the team will not do.
- Behavioural compartmentation measures for the four team members.

Deliverable 5: Communications Plan (14 points)

- All ten elements from Section 1.8.5.
- **The client-channel problem addressed explicitly**: how the team communicates with the Authority's general counsel given that the Authority's IT is outsourced to a provider serving Ardent and that a member of Authority staff may be a subject.
- Verification for every party, including those never met.
- Naming discipline covering subject lines, file names, calendar entries, and physical conversation.
- The interview arrangements, given that Ardent staff are on the premises.
- The compromise procedure.

Deliverable 6: Metadata Protection Plan (12 points)

- What is stripped, what is preserved, and the rule that distinguishes them.
- The pre-publication workflow for the final report and any interim product, ending in verification.
- Image handling, including any imagery you produce or receive.
- The internal circulation position: what metadata is acceptable inside the firm.
- **A statement on collected evidence metadata**, which is never stripped, and how the two workflows are kept separate.
- The organizational footprint audit: what your own firm publishes that could attribute this work.

Deliverable 7: Attribution Minimization Plan (12 points)

- Every attribution signal this engagement will generate, from Section 1.9.2, with the measure applied to each.
- Which signals cannot be prevented, and the plan for them: timing, disclosure to the client, or acceptance.
- **The records request question**: whether any request will be disclosed to affected parties, and how that is timed and communicated to the client.
- The physical and social dimension, given Ardent's presence on the client's premises.
- The aggregation analysis: which combinations of unavoidable traces would identify the

investigation, and what breaks the combination.

Deliverable 8: Justification and Proportionality Statement (10 points)

For each significant measure: the risk it addresses, why it is proportionate, what it costs in time or capability, what was considered and rejected as over-engineering, and the ethical and legal considerations bearing on it (Chapter 7). Minimum twelve measures. **At least two measures should be ones you considered and rejected as disproportionate**, with the reasoning.

Deliverable 9: Review and Sustainment (8 points)

- Review points aligned to Chapter 6's, with an OPSEC checklist of no more than twelve items.
- What is reassessed at each, and what would trigger an unscheduled reassessment.
- The sustainment question: which measures are most likely to be abandoned under deadline pressure, and what makes them easier to keep.
- The closure procedure: accounts closed, environments destroyed, material disposed of per Chapter 7, and what is recorded.
- What the client is told about the OPSEC posture, and what they are told if it fails.

9.4 Capstone Grading Rubric (110 points, scored to 100)

Deliverable	Criterion	Points
1. Threat model	Critical information, eight-plus items	3
	Adversaries specific, with honest capability	5
	Vulnerabilities, fifteen-plus, by activity	4
	Risk assessment with a stated method	4
	Posture level, proportionate and justified	2
2. Isolation	Profile and VM architecture, per person and activity	4
	What each layer does not address, stated	3
	Evidence quality impact and capture recording	4
	Managed-device path	3
3. Network	Configuration per activity with	3

Deliverable	Criterion	Points
	reasons	
	Exit decisions and their effect on retrieved content	2
	Client-network question addressed	3
	Tor position and policy compliance	2
4. Identity	Compartmentation level with reason	3
	Account register with closure triggers	3
	Linking risks including recovery details	3
	Rules 2 and 9 boundary stated explicitly	3
5. Communications	All ten elements	3
	Client-channel problem addressed	5
	Verification for all parties	2
	Naming discipline including physical conversation	2
	Interview arrangements given on-site presence	2
6. Metadata	Strip and preserve rule stated clearly	3
	Pre-publication workflow ending in verification	4
	Evidence metadata never stripped, workflows separated	3
	Own-firm footprint audit	2
7. Attribution	Signals enumerated with measures	4
	Unpreventable signals identified with a plan	3
	Records request disclosure timed and communicated	3
	Aggregation analysis	2
8. Justification	Twelve-plus measures with risk,	6

Deliverable	Criterion	Points
	proportionality, and cost	
	Two-plus measures rejected as over-engineering, with reasoning	4
9. Review	Review points and a twelve-item checklist	3
	Sustainment analysis	2
	Closure procedure	2
	Client communication about the posture	1
Total		110, scored to 100

Grade bands: 90 to 100 exemplary, 80 to 89 proficient, 70 to 79 competent, 60 to 69 developing, below 60 not yet passing.

Automatic deductions:

- Proposing any false persona, fabricated account identity, or any measure whose purpose is obtaining access rather than protection: **minus 30**. Rule 9.
- Proposing to circumvent your own firm's or the client's security controls: minus 15.
- Treating the client's environment as a safe channel, given the stated facts: **minus 15**.
- Proposing any activity Rule 4 prohibits: minus 15.
- No evidence quality impact analysis: minus 10.
- Stripping metadata from collected evidence, or failing to distinguish the two workflows: minus 10.
- A posture that is disproportionate to the stated threat model, in either direction, without reasoning: minus 8.
- No measures rejected as over-engineering: minus 6.
- Recommending measures that require capability the four-person team does not have, without saying so: minus 6.

Guidance on the expected shape of a strong plan. The threat model should identify at least: Ardent's staff on the client's premises, Ardent's marketing or IT staff watching their own analytics, the possibly implicated procurement officer with system access, the outsourced IT provider serving both parties, and the officers of Ardent's parent in another jurisdiction. The client-channel problem is the plan's centrepiece and should be resolved by communicating with general counsel through a channel outside the Authority's own systems, agreed with counsel at the outset, with a case designation used throughout. Isolation should be modest and sustainable: separate profiles per person as the baseline, a VM only for the technical footprint work, and no personal devices. The network strategy should use

direct connections for most records research, a VPN with recorded exits for anything touching Ardent's own web properties, and archived pages in preference to live visits. Records requests should be assessed for disclosure to affected parties, and where disclosure is likely, the timing decision should be presented to counsel rather than absorbed. Attribution minimization should recognize that the physical and conversational dimension is the hardest problem here, because Ardent staff are on site, and that the strongest measure is naming discipline and a case designation rather than anything technical. And the justification statement should reject at least two plausible-sounding measures, such as per-case device compartmentation or Tor for records research, as disproportionate to a nine-week commercial engagement with four people.

Part 10: Answer Keys

Instructors may wish to remove this section from student copies.

10.1 Short Answer Key

1. OPSEC is identifying information about your own activity that an adversary could use, assessing the risk, and applying proportionate measures. The cycle: identify critical information, identify threats, analyse vulnerabilities, assess risk, apply countermeasures, review.
2. A threat model states what you are protecting, from whom specifically, what that adversary can actually do, and what happens if they succeed. Two investigations differ because those answers differ: a commercial diligence engagement facing a marketing team watching analytics and a source-protection engagement facing a state actor require different postures, and applying either's measures to the other fails in both directions.
3. Under-protection leaves the exposures open; over-engineering applies measures beyond the threat model. Over-engineering is dangerous rather than merely wasteful because the measures are abandoned under deadline pressure, usually silently, leaving no protection while the team still believes it is protected.
4. Because the technical controls are usually the part that was designed deliberately, and the failure occurs in the parts that were not: behaviour (a logged-in session, a personal device used once), social exposure (a conference conversation, an out-of-office reply), and documentary exposure (metadata in a delivered report).
5. Any two of: a VPN exit in another geography returns different content, so the capture may not reflect what a local user sees; aggressive blocking breaks rendering and produces incomplete captures; isolated environments create transfer friction that complicates hashing and custody; disposable sessions can cause sites to behave differently. The rule is to record the configuration in every capture record and to prefer the configuration producing the most representative capture unless the threat model requires otherwise.
6. Any six of: IP address, reverse DNS, user agent, language and locale, time zone, screen and window characteristics, fonts and rendering behaviour, referring page, cookies, logged-in session, and timing

patterns. The most consequential is the logged-in session, because it discloses identity directly and defeats every other measure.

7. Fingerprinting identifies a browser by the combination of its observable characteristics rather than a stored identifier. Adding privacy extensions makes a browser rarer, and rarity is what fingerprinting exploits, so a heavily customized browser can be more identifiable than a default one.

8. Does: prevents local history retention, isolates cookies for the session, discards them at close, prevents local autofill and cached credential use. Does not: hide your IP address, prevent fingerprinting, hide activity from your network operator or employer, or hide anything from the sites you visit.

9. Provides separate cookies and storage, separate signed-in state, separate history and autofill, and separate extensions, plus a deliberate context switch. Does not provide any change to IP address or fingerprint, or protection against a compromised host. Disciplines: never sign in to a personal account there, never use it for personal browsing, disable synchronization, minimize extensions, name the profile, and use one profile per case where cases must not be linked.

10. VMs have a separate kernel and a hypervisor boundary, giving strong isolation, native snapshots and rollback, and suitability for hostile content. Containers share the host kernel, giving moderate isolation, excellent reproducibility, low cost, and unsuitability as a boundary against hostile content.

11. Because a VM's traffic by default leaves through the host's network connection, so the visited site sees the same address. What changes the address is a network measure: a different network, a VPN, or Tor.

12. A VPN does not remove the party who can see your activity; it replaces your network operator with the VPN provider. Questions: what does it log and for how long, where is it established and under whose compulsion, who owns it, has it been independently audited, does it leak DNS or fail open, and are its addresses widely recognized as VPN addresses.

13. With a VPN a single party, the provider, sees both your identity and your destinations. Tor routes through multiple relays with layered encryption so that the entry relay knows your address but not your destination, the exit knows the destination but not your address, and no single relay sees both.

14. Any four of: it is slow; many sites block known exit addresses; exit locations vary unpredictably, which harms evidentiary capture; exit relays can observe unencrypted traffic; using it is observable to your local network; and institutional policy frequently prohibits it.

15. A compartmentalized identity is a separate professional account set that does not claim to be anyone in particular and exists to separate personal life from professional work. A false persona presents as someone who does not exist or as someone else, and exists to obtain access. The test: if the purpose is preventing your personal life from attaching to your work, it is compartmentation; if the purpose is being treated as someone you are not so that access is granted, it is a false persona and it is prohibited.

16. Two accounts that appear entirely separate are linked if both list the same recovery email address or phone number. It is the most common silent failure because recovery details are set once at account

creation, are rarely reviewed, and are invisible in ordinary use.

17. In transit protects data moving between you and a server and is readable by the server operator. At rest protects stored data and is readable by anyone with the key or an unlocked device. End to end means only the endpoints hold keys, so the operator cannot read content. E2EE does not protect metadata, endpoints, backups, recipients' behaviour, or group membership.

18. Because encryption is visible and authentication is not: a channel that shows a lock feels safe, and an encrypted channel to an impostor is worse than an unencrypted one. Verification requires comparing a safety number or fingerprint through a channel independent of the one being verified, and re-verifying after any key change notification.

19. Any six, with at least three non-technical: IP and reverse DNS, account identity, fingerprint, cookies, timing patterns, behavioural patterns, document metadata, email headers, payments, records requests, social ties, language and locale, and physical presence. They aggregate because individually innocuous traces combine: an address range, a reverse DNS name, a working-hours pattern, a profile view, and a disclosed records request together identify the firm, the person, the timing, and the subject.

20. A redaction failure is visually obscuring content, typically with a black rectangle, that remains in the file and is selectable and extractable. True redaction removes the content, exports a new file, and verifies by extracting text from the result and confirming the removed content is absent. Collected evidence metadata is never stripped, because it is part of the item; stripping applies to material leaving your control.

10.2 Multiple Choice Key

#	Answer	Note
1	b	OPSEC never buys access
2	c	Risk assessment
3	c	The logged-in session
4	b	Rarity increases distinctiveness
5	c	A local privacy feature
6	b	Uses the host's connection by default
7	b	Shared host kernel
8	b	The trust shift
9	b	No single relay sees both ends
10	b	Compartmentation, permitted
11	b	Shared recovery details
12	c	Metadata, endpoints, and backups
13	b	Out-of-band communications

#	Answer	Note
14	b	The text remains extractable
15	c	Collected evidence

10.3 True or False Key

#	Answer	If false, why
1	False	It is a local privacy feature and provides almost nothing against the visited site
2	True	
3	False	A fingerprint is derived from browser characteristics, not stored identifiers, so clearing cookies does not change it
4	False	A signed-in session discloses identity directly, regardless of the network path
5	False	The local operator can see that Tor is in use, along with volume and timing
6	False	Unsustainable measures are abandoned under pressure, leaving no protection and a false belief in it
7	False	Disposability requires a clean snapshot and an actual rollback policy; without them the VM becomes a second unmanaged machine
8	True	
9	True	
10	False	Evidence metadata is part of the evidence and is never stripped; stripping applies to material leaving your control

10.4 Critical Thinking Guidance

7.1 Traces: eleven site visits from a corporate range with identifying reverse DNS, visible in the employer's analytics; three profile views that may notify the individuals by name; a records request that

may be disclosed to the employer; and a link in an email that may generate a fetch. Aggregate: the employer can identify the firm, the individual investigator, the timing, and the subject matter, and can infer the client from context.

7.2 Graded on specificity of adversary and honesty of capability. The change from commercial harm to physical risk should move the posture from moderate to high and should also raise the question of whether the work should proceed in that form at all, with organizational support and legal advice.

7.3 Acceptable answers include: a logged-in personal session in the investigation profile; the client named in a calendar entry or out-of-office reply; metadata in the delivered report; a case discussed at a conference or in an office; a records request disclosed to the subject; a shared recovery detail linking compartments; and nothing recorded, so no one can tell what happened.

7.4 (a) A direct connection with a separate profile; nothing more is warranted. (b) A VM with a VPN, passive sources first, no interaction with the page. (c) Archived captures where possible, spaced live visits through a VPN with recorded exits, and awareness that a weekly pattern is itself a signal. (d) Out-of-band, end-to-end encrypted, verified, with organizational support and a channel the source chooses. (e) Separate profile, archives, VPN with recorded exit, no profile views, naming discipline, and a records request timing decision presented to the client.

7.5 The proposal is over-engineering for most investigations: it is slow, it degrades evidence capture, it is unlikely to be sustained, and the double-VPN element adds little. The alternative is a threat model first, then separate profiles as the baseline, a VM for hostile content, and a single VPN with recorded exits where organizational attribution matters.

7.6 Reasonable order: separate browser profiles for everyone with the sign-in discipline; a case designation and naming discipline including calendars and out-of-office replies; an account register with recovery-detail audit; multi-factor authentication on every case-relevant account; the pre-publication metadata workflow; and a decision log so that everything after is recorded. All are free.

7.7 Graded on whether each configuration's coverage is stated accurately: the profile changes session state only, the VPN changes the network only, the VM addresses hostile content only, and the combination addresses more but not fingerprinting or behaviour. The choice should follow the threat model defined by the student.

7.8 The capture does not represent what the relevant audience sees, which matters because pricing and availability vary by geography. It should have been captured from the relevant geography, or from a documented exit in that geography. What is recorded: the exit location, the time, the configuration, and a note that geographic variation was observed.

7.9 The conflict is that using a personal VPN to bypass the organization's monitoring is a policy violation and removes protections the organization relies on. Two proper resolutions: the organization provisions an approved egress path for investigative work with the security team's knowledge, or the work is conducted from an approved separate network or environment the organization provides.

7.10 Per-case profiles at minimum, with per-case accounts where cases must not be linked; a shared firm-level records subscription is a linking risk and should be assessed. The register lists every account

with owner and closure trigger; the linking risks are recovery details, shared subscriptions, device sharing, and behavioural patterns; closure occurs at case end with the accounts recorded as closed.

7.11 Six links: shared recovery email or phone; the same device with shared browser state; reused passwords; the same profile photograph, reverse-searchable; identical writing style; and identical activity timing. Controls: separate recovery details, separate profiles or devices, a password manager with unique credentials, no reused images, awareness of writing patterns, and where necessary deliberate variation of activity timing.

7.12 The response should decline: an account created to look like a normal customer, where that means presenting as someone you are not to obtain access, is a false persona under Rule 2 and is not OPSEC under Rule 9. The lawful alternatives include requesting the pricing through a proper channel, examining published or archived pricing, obtaining pricing from the client's own procurement records, or purchasing the product openly where that is lawful and disclosed.

7.13 Graded against the ten elements in Section 1.8.5, with particular attention to whether the source's channel is separated from client channels and whether naming discipline covers subject lines and calendars.

7.14 Four remaining exposures: metadata visible to the operator, including who and when; endpoints, so a compromised or unlocked device exposes everything; backups, which may be unencrypted; and recipients' behaviour, including screenshots and forwarding. Mitigations: naming discipline so metadata reveals less, device encryption and screen locks, backup settings reviewed, and an agreement on handling.

7.15 Compare email attachment, encrypted archive with an out-of-band passphrase, a managed portal, and physical media. The portal usually wins on auditability and access expiry, which matters most for a client delivery, and it satisfies Chapter 6's production log requirement most easily.

7.16 Screenshots: capture tool metadata and any window content revealing internal systems. Charts exported from a spreadsheet: may carry document properties and, in some formats, source data. The photograph: GPS, device, photographer, and an embedded thumbnail. Steps: strip document metadata, re-export images rather than cropping in place, strip image metadata, export to a new file, and verify by re-reading the output.

7.17 Test by selecting and copying the text under the boxes, or by extracting text from the file, and comparing it with what is visible. If the text is present, the redaction has failed: notify the publisher immediately, do not redistribute, and record what was found and when. The publisher should have removed the content and produced a new file, then verified by extraction.

7.18 Graded on effort and honesty. A five-minute review of published documents will typically reveal author names, software versions, and sometimes internal paths, and job postings will reveal the technology estate.

7.19 Can still be improved: profiles, naming discipline, calendars, out-of-office replies, metadata workflow, account register, and a decision log. Cannot be undone: profile views already notified, visits already logged in the subject's analytics, records requests already disclosed, and anything already

published. The client should be told what has already been exposed, what remains at risk, and what is being changed.

7.20 Twelve items maximum, drawn from Appendix B, weighted toward the behavioural and documentary rather than the technical.

7.21 The two paragraphs should state the risk in terms of consequence rather than technology, state the cost honestly as a percentage and in days, state the recommendation, and offer the alternative of accepting the risk with the client's informed agreement, recorded.

Appendix A: Reusable Templates

A.1 Threat Model Record

INVESTIGATION: _____ DATE: _____

1. CRITICAL INFORMATION (what would harm us if known)

2. ADVERSARIES (specific; who within an organization)

3. CAPABILITY (what they can actually do, not imagine)

4. CONSEQUENCE (if they succeed)

POSTURE LEVEL: LOW / MODERATE / HIGH REASON: _____

ACTIVITIES REQUIRING A DIFFERENT LEVEL: _____

REVIEW DATE: _____ RECORDED BY: _____

A.2 Vulnerability and Risk Register

#	Activity	Trace generated	Observable by	Likelihood	Consequence	Rating	Countermeasure	Residual
---	----------	-----------------	---------------	------------	-------------	--------	----------------	----------

A.3 Workspace Configuration Record

Element	Decision	Reason	Verified how
Profile name and convention			
Synchronization			
Extensions			
Signed-in state policy			
Cookie and site data policy			
Default search			
VM used? Snapshot and			

Element	Decision	Reason	Verified how
rollback			
Shared folders and clipboard			
Network configuration			
Evidence transfer workflow			
Closure action			

A.4 Capture Configuration Note

Attach to every capture record (Chapter 6).

ITEM ID: _____ DATE/TIME (TZ): _____
 PROFILE USED: _____ EXTENSIONS ACTIVE: _____
 NETWORK PATH: direct / VPN (exit: _____) / other: _____
 ENVIRONMENT: host / VM (name: _____)
 SIGNED-IN STATE: none / _____
 CONTENT BLOCKING ACTIVE: Y / N DETAIL: _____
 GEOGRAPHIC VARIATION OBSERVED: Y / N DETAIL: _____
 REPRESENTATIVENESS NOTE: _____

A.5 Account Register

Account	Purpose	Owner	Created	Recovery details (and what they link to)	MFA	Closure trigger	Closed

A.6 Communications Plan

Element	Decision
Parties	
Content categories	
Channel per category, with reason	
Prohibited channels	
Verification method per party	
Re-verification triggers	
File sharing method and controls	
Account and device requirements	
Naming discipline (subject lines, files, calendars,	

Element	Decision
conversation)	
Case designation	
Retention and removal	
Compromise procedure	
Out-of-office and delegation	

A.7 Pre-Publication Metadata Checklist

FILE: _____ DESTINATION: _____

1. Content to be removed is DELETED, not hidden []
2. Tracked changes accepted or rejected; none remain []
3. All comments deleted []
4. Hidden rows, slides, layers removed []
5. Document properties stripped (author, company, manager, template, keywords, editing time, revisions) []
6. Embedded images re-exported, not cropped in place []
7. Image metadata stripped (GPS, device, artist) []
8. Embedded thumbnails eliminated []
9. File paths and internal hostnames removed from text []
10. Exported to a NEW file []
11. VERIFIED: text extracted from the output and searched for content that should be absent []
12. VERIFIED: output properties re-read []
13. Hash recorded and recipient logged []

PERFORMED BY: _____ DATE: _____ SIGN-OFF: _____

A.8 Attribution Signal Checklist

Signal	Present in this engagement?	Measure	Residual	Unavoidable?
IP address and reverse DNS				
Account identity and profile views				
Fingerprint				
Cookies				
Timing patterns				
Behavioural patterns				
Document metadata				
Email headers				
Payments and				

Signal	Present in this engagement?	Measure	Residual	Unavoidable?
subscriptions				
Records requests				
Social ties and conversation				
Physical presence				

A.9 OPSEC Assessment Worksheet

#	Observation	Category	Exposures	To whom	Likelihood	Consequence	Rating	Remediable?	Recommendation	Cost
---	-------------	----------	-----------	---------	------------	-------------	--------	-------------	----------------	------

Appendix B: The OPSEC Review Checklist

Twelve items, run at every Chapter 6 review point.

1. Does a written threat model exist, and has anything changed that would alter it?
2. Is any team member using a personal account or device for case activity?
3. Has anyone signed in to a personal account in an investigation profile?
4. Are subject sites being visited live where an archive would serve?
5. Are all case-relevant accounts on multi-factor authentication, with recovery details that link nothing?
6. Do any calendar entries, subject lines, file names, or out-of-office replies name the client, the subject, or the case?
7. Has any material left the firm without the pre-publication metadata workflow and its verification step?
8. Has any evidence had its metadata stripped? (This should never happen.)
9. Have any records requests been filed that will be disclosed to affected parties, and does the client know?
10. Is every capture record carrying its configuration note?
11. Are the measures we designed actually being followed, and if not, which one was dropped first?
12. Is any of this written down?

Item 11 is the one that matters. The measure dropped first under pressure is the one to redesign, not the one to insist on.

Appendix C: Where to Go Next

Skills to build after this chapter, in priority order:

1. **Build the profile discipline until it is automatic.** It is free, it prevents the worst failure, and it is only useful if it is habitual.
2. **Practise threat modelling on ordinary situations**, not just investigations. Four questions, five minutes, written down. It is the skill that makes every other decision proportionate.
3. **Run the pre-publication workflow on something real**, including the verification step, until you have caught at least one thing you would have released.
4. **Audit your own footprint** the way Chapter 3 taught you to audit others, and then do the same for your organization's published files.
5. **Learn your organization's policy** on VPNs, virtualization, personal devices, and external communication tools, before you need it.
6. **Practise verification** in an encrypted messaging application: compare a safety number with someone in person, then observe what happens when a key changes.
7. **Read your industry's incident reports** for the OPSEC failure rather than the technical one. It is nearly always there and it is nearly always behavioural.

Habits to start now:

- One profile for work, one for life, and never sign in across them.
 - Record the configuration with every capture.
 - Assume the calendar entry is public.
 - Verify before you trust the lock icon.
 - Extract the text before you publish the redaction.
 - Choose the measure you will still be following in week six.
-

End of Chapter 8